

Daily Vulnerability Report - 2026-09-10

Window (UTC): 2026-09-10T00:00 to 2026-09-11T00:00 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-17 05:55:46 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
1304	17	175	603	476	35	14	540

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2016-4117	9.8	CRIT	Yes	0.944	adobe:flash_player, opensuse:evergreen, opensuse:opensuse, redhat:enterprise_linux_desktop, redhat:enterprise_linux_serv	Adobe Flash Player 21.0.0.226 and earlier allows remote attackers to execute arbitrary code via unspecified vectors, as exploited in the wild in May 2016.
CVE-2022-41352	9.8	CRIT	Yes	0.955	synacor:zimbra_collaboration_suite	An issue was discovered in Zimbra Collaboration (ZCS) 8.8.15 and 9.0. An attacker can upload arbitrary files through amavis via a cpio loophole (extraction to /opt/zimbra/jetty/webapps/zimbra/public) that can lead to incorrect access to any other user accounts. Zimbra recommends pax over cpio. Also, pax is in the prerequisites of Zimbra on Ubuntu; however, pax is no longer part of a default Red Hat installation af...
CVE-2025-25249	9.8	CRIT	Yes	0.024	fortinet:fortios, fortinet:fortisase, fortinet:fortiswitchmanager, siemens:ruggedcom_ape1808, siemens:ruggedcom_ape1808_	A heap-based buffer overflow vulnerability in Fortinet FortiOS 7.6.0 through 7.6.3, FortiOS 7.4.0 through 7.4.8, FortiOS 7.2.0 through 7.2.11, FortiOS 7.0.0 through 7.0.17, FortiOS 6.4 all versions, FortiSwitchManager 7.2.0 through 7.2.6, FortiSwitchManager 7.0.0 through 7.0.5 allows attacker to execute unauthorized code or commands via specially crafted packets
CVE-2026-19490	9.3	CRIT	Yes	0.056	citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Vulnerability in NetScaler ADC and NetScaler Gateway. This issue affects ADC: from 14.1 through 73.32 and from 13.1 through 63.21; Gateway: from 14.1 through 73.32 and from 13.1 through 63.21.
CVE-2026-87491	8.8	HIGH	Yes	0.01	google:chrome	Out of bounds write in V8 in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2016-7255	7.8	HIGH	Yes	0.81	microsoft:windows_10_1507, microsoft:windows_10_1511, microsoft:windows_10_1607, microsoft:windows_7, microsoft:windows_	The kernel-mode drivers in Microsoft Windows Vista SP2, Windows Server 2008 SP2 and R2 SP1, Windows 7 SP1, Windows 8.1, Windows Server 2012 Gold and R2, Windows RT 8.1, Windows 10 Gold, 1511, and 1607, and Windows Server 2016 allow local users to gain privileges via a crafted application, aka "Win32k Elevation of Privilege Vulnerability."
CVE-2022-37969	7.8	HIGH	Yes	0.283	microsoft:windows_10_1507, microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_20h2, microsoft:wi	Windows Common Log File System Driver Elevation of Privilege Vulnerability
CVE-2026-42016			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-42018			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-58704			Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-67277			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.
CVE-2026-76460			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-84869			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-86060			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-87886			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.
CVE-2026-42945	9.2	CRIT		0.68	f5:dos, f5:nginx_gateway_fabric, f5:nginx_ingress_controller, f5:nginx_instance_manager, f5:nginx_open_source, f5:nginx_	NGINX Plus and NGINX Open Source have a vulnerability in the ngx_http_rewrite_module module. This vulnerability exists when the rewrite directive is followed by a rewrite, if, or set directive and an unnamed Perl-Compatible Regular Expression (PCRE) capture (for example, \$1, \$2) with a replacement string that includes a question mark (?). An unauthenticated attacker along with conditions beyond its control can exp...

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2020-14498	10.0	CRIT		0.04	hms-networks:ecatcher	HMS Industrial Networks AB eCatcher all versions prior to 6.5.5 is vulnerable to a stack-based buffer overflow, which may allow an attacker to remotely execute arbitrary code.
CVE-2026-42043	10.0	CRIT		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, an attacker who can influence the target URL of an Axios request can use any address in the 127.0.0.0/8 range (other than 127.0.0.1) to completely bypass the NO_PROXY protection. This vulnerability is due to an incomplete for CVE-2025-62718, This vulnerability is fixed in 1.15.1 and 0.31.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77770	10.0	CRIT		0.002		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not require a validated transaction before deleting site options whose names come from unauthenticated request input, allowing any visitor to delete arbitrary options, which can lock every administrator out of the dashboard or deactivate every miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress...
CVE-2026-86152	10.0	CRIT		0.019		A flaw has been found in Tenda CP3 27.5.57.101. The impacted element is the function CAutoAddWifi::ThreadProc of the file Functions/AutoAddWifi.cpp of the component Kylin. Executing a manipulation can lead to os command injection. The attack may be launched remotely.
CVE-2026-19583	9.9	CRIT		0.006		Velociraptor allows some sensitive artifacts to be gated by additional permissions. For example, the Linux.Sys.BashShell artifact allows arbitrary command execution on endpoints, and so it requires the EXECVE permission to schedule. However, no such check was implemented for client monitoring artifacts. Additionally there was no requirement that client monitoring artifacts carry the CLIENT_EVENTS type. This allows...
CVE-2026-22797	9.9	CRIT		0.007		An issue was discovered in OpenStack keystonemiddleware 10.5 through 10.7 before 10.7.2, 10.8 and 10.9 before 10.9.1, and 10.10 through 10.12 before 10.12.1. The external_oauth2_token middleware fails to sanitize incoming authentication headers before processing OAuth 2.0 tokens. By sending forged identity headers such as X-Is-Admin-Project, X-Roles, or X-User-Id, an authenticated attacker may escalate privileges ...
CVE-2026-52855	9.9	CRIT		0.003		Wings is the server control plane for Pterodactyl, a free, open-source game server management panel. Prior to 1.12.3, {{config.}} placeholders in egg configuration-file templates allow a low-privileged user to read {{config.token}}, {{config.token_id}}, and {{config.docker.registries}} from the full daemon configuration. This issue is fixed in version 1.12.3.
CVE-2026-54680	9.9	CRIT		0.005		Logging operator automates the deployment and configuration of Kubernetes logging pipelines. Prior to 6.6.0, the Fluentd configuration renderer FluentRender in pkg/sdk/logging/model/render/fluent.go writes CRD strings such as Flow record_transformer.records values directly into fluent.conf without escaping, allowing a user who can create Flow resources to inject a Fluentd <match *> block using @type exec and exec...
CVE-2026-67401	9.9	CRIT		0.01		A vulnerability in cPanel allows a mail-enabled account to achieve remote code execution as root through SQLi in EmailTrack component
CVE-2026-68487	9.9	CRIT		0.004		Path traversal in Plesk's Backup Manager causes arbitrary file write as root by an authenticated customer.
CVE-2026-68488	9.9	CRIT		0.002		A Time-of-check Time-of-use (TOCTOU) race condition leading to insecure symlink following in Plesk causes local privilege escalation to root via arbitrary file/directory ownership takeover.
CVE-2026-7374	9.9	CRIT		0.007		A flaw was found in KubeVirt's virt-handler component. This vulnerability allows an authenticated OpenShift user with edit permissions in a single namespace to exploit improper symlink validation when connecting to virtual machine console sockets. By replacing the console socket with a symlink to the host's container runtime (CRI-O) socket, an attacker can hijack virt-handler's privileged connection. This enables ...
CVE-2026-89094	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2024-22373	9.8	CRIT		0.016	fedoraproject:fedora, malaterre:grassroots_dicom	An out-of-bounds write vulnerability exists in the JPEG2000Codec::DecodeByStreamsCommon functionality of Mathieu Malaterre Grassroot DICOM 3.0.23. A specially crafted DICOM file can lead to a heap buffer overflow. An attacker can provide a malicious file to trigger this vulnerability.
CVE-2026-18351	9.8	CRIT		0.008		The Drag and Drop File Upload for Elementor Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.6.0 via the elementor_file_upload function. This is due to insufficient file type validation in the is_file_type_valid() function, which uses the attacker-controlled 'type' parameter as regex keys in the MIME allowlist, allowing blacklist bypass via a crafted extensi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-18658	9.8	CRIT		0.004		IBM Operational Decision Manager 9.6.0.0, 9.5.0.0, 8.11.1.0, 8.11.0.1, 8.12.0.1, 9.5.0.1, and 9.0.0.1 is vulnerable to SQL injection. An unauthenticated attacker can execute arbitrary SQL statements and leverage database functionality to write a web shell to the application web root, resulting in remote code execution.
CVE-2026-33815	9.8	CRIT		0.006	jackc:pgx	Memory-safety vulnerability in github.com/jackc/pgx/v5.
CVE-2026-33816	9.8	CRIT		0.006	jackc:pgx	Memory-safety vulnerability in github.com/jackc/pgx/v5.
CVE-2026-36433	9.8	CRIT		0.005		An issue in Actions Semiconductor Co. Ltd Tool- Media Player Utilities v.4.46 allows a physically proximate attacker execute arbitrary code via the Production.dll and RdiskUpgrade.exe components
CVE-2026-38626	9.8	CRIT		0.003		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-41871	9.8	CRIT		0.008	apache:nutch	Missing Authorization, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted use...
CVE-2026-47884	9.8	CRIT		0.004	vmware:spring_framework	Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/"**" mapping that results in view rendering, and where the view name is not explicitly specified. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-4800	9.8	CRIT		0.028	lodash:lodash, lodash:lodash-amd, lodash:lodash-es, lodash:lodash.template	Impact: The fix for CVE-2021-23337 (https://github.com/advisories/GHSA-35jh-r3h4-6jhm) added validation for the variable option in _.template but did not apply the same validation to options.imports key names. Both paths flow into the same Function() constructor sink. When an application passes untrusted input as options.imports key names, an attacker can inject default-parameter expressions that execute arbitra...
CVE-2026-52098	9.8	CRIT		0.008	flowiseai:flowise	An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowId> endpoint
CVE-2026-52889	9.8	CRIT		0.007		Formie is a Craft CMS plugin for creating forms. Prior to 3.1.27, Formie can pass request-derived Hidden field defaults such as HTTP User Agent, Referer URL, Current URL, Current URL without Query String, Query Parameter, and Cookie Value to Craft's Twig rendering layer during front-end form rendering. An unauthenticated attacker can place Twig syntax in one of these request-controlled inputs when a public form co...
CVE-2026-53002	9.8	CRIT		0.004	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: netfilter: conntrack: remove sprintf usage Replace it with scnprintf, the buffer sizes are expected to be large enough to hold the result, no need for snprintf+overflow check. Increase buffer size in mangle_content_len() while at it. BUG: KASAN: stack-out-of-bounds in vsnprintf+0xea5/0x1270 Write of size 1 at addr [...] vsnprintf+0xea5/0x1270 ...
CVE-2026-56207	9.8	CRIT		0.005	apache:impala	Signature of Bearer token is not verified in last step of SAML2 authentication for Impala's hs2-http interface, allowing altering user name and acting as another user. This issue affects Apache Impala: >=4.0.0. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-57967	9.8	CRIT		0.007	apache:artemis	An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68502	9.8	CRIT		0.007		LazyOwn RedTeam/APT Framework is an AI-powered C2 and red-team operations framework. Prior to 0.2.154, LazyOwn's lazyc2.py registers an unauthenticated Socket.IO input event handler that dispatches data.get("value") to LazyOwnShell.one_cmd, reaching LazyOwnShell.do_cmd and subprocess.call(command, shell=True), allowing unauthenticated remote code execution in the C2 process. This issue is fixed in 0.2.154.
CVE-2026-68503	9.8	CRIT		0.005		LazyOwn RedTeam/APT Framework is an AI-powered C2 and red-team operations framework. Prior to 0.2.154, LazyOwn ships default C2 credentials LazyOwn and LazyOwn in payload.json and core/payload_schema.py and passes them unchanged to lazyc2.py HTTP Basic authentication, allowing any network-reachable attacker who knows the defaults to authenticate to the C2 dashboard with operator-level access. This issue is fixed i...
CVE-2026-69240	9.8	CRIT		0.004		Sequelize is a Node.js ORM tool. Prior to 6.37.4, SQL injection is possible with strings only if dialect is set to oracle. The escape function defined in sql-string.js does not escape quotes if the value starts with TO_TIMESTAMP or TO_DATE. In the Oracle dialect, when val is a string and starts with TO_TIMESTAMP or TO_DATE, escape returns val directly instead of replacing single quotes. An attacker can inject arbi...
CVE-2026-69579	9.8	CRIT		0.01		Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-69715	9.8	CRIT		0.01		Out-of-bounds read in Windows Direct Show allows an unauthorized attacker to execute code over a network.
CVE-2026-69730	9.8	CRIT		0.011		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69768	9.8	CRIT		0.009		Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to execute code over a network.
CVE-2026-69824	9.8	CRIT		0.01		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an unauthorized attacker to execute code over a network.
CVE-2026-69845	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-71805	9.8	CRIT		0.004		An arbitrary file upload and path traversal vulnerability exists in LZ-litchi 1.0.0. Unauthenticated remote attackers can upload arbitrary files and write them outside the intended storage directory via the directory parameter in POST /app-api/infra/file/upload.
CVE-2026-7188	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows SQL Injection. This issue affects Access Control System: before Versiyon 2.
CVE-2026-73778	9.8	CRIT		0.003	hpe:aruba_cx_10000-48y6c_(r8p13 a), hpe:aruba_cx_10000-48y6c_(r8 p14a), hpe:aruba_cx_10000-48y6c_(s0f98a), hpe:aruba	A vulnerability exists in the Credential Manager component that may allow for unauthorized administrative access. An unauthenticated remote attacker could exploit this vulnerability on a device in its factory-default or post-ZTP state before any administrator has configured credentials by providing a predictable factory-default password. Successful exploitation could result in full administrative control of the af...
CVE-2026-75003	9.8	CRIT		0.004	roundcube:webmail	In Roundcube Webmail before 1.6.18 and 1.7.x before 1.7.3, an unclosed url() in a FuncIRI attribute of an SVG image could evade the remote image blocking, which may lead to information disclosure or privilege escalation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77493	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78573	9.8	CRIT		0.004	ibm:contextforge	IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-79724	9.8	CRIT		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-80351	9.8	CRIT		0.005	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privileges of the operator. This issue affect...
CVE-2026-80352	9.8	CRIT		0.004	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users ...
CVE-2026-81204	9.8	CRIT		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467	9.8	CRIT		0.038	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-85025	9.8	CRIT		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-85102	9.8	CRIT		0.003		Improper certificate trust validation during VPN negotiation in Check Point Quantum Security Gateway may allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.
CVE-2026-85103	9.8	CRIT		0.004		A heap-based buffer overflow in VPN certificate ASN.1 decoding may allow an unauthenticated remote attacker to execute arbitrary code on Check Point Quantum Security Management and Quantum Security Gateway systems.
CVE-2026-87534	9.8	CRIT		0.002	google:android, google:chrome	Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-88018	9.8	CRIT		0.005	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, while Server.auth passes the access key id...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88278	9.8	CRIT		0.003		GeoVision GV-LPC2211 V1.13 fails to enforce WS-Security UsernameToken freshness or nonce reuse protection, allowing a captured PasswordDigest token to be replayed for subsequent ONVIF operations.
CVE-2026-9163	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.
CVE-2026-54694	9.6	CRIT		0.003		SkillTree is a micro-learning gamification platform. Prior to version 4.4.2, two independent code flaws combine into a single exploitable attack chain, with three distinct exploitation paths of escalating impact. `StringHighlighter.js` builds an HTML string by interpolating raw `value` substrings directly into a template literal with no HTML entity encoding. `HighlightedValue.vue` renders that string — and all unf...
CVE-2026-54725	9.6	CRIT		0.004		vault-secrets-webhook is a Kubernetes mutating webhook that makes direct secret injection into Pods possible. Prior to 1.23.1, parseVaultConfig() in pkg/webhook/config.go accepts the vault.security.banzaicloud.io/vault-addr annotation, MutateConfigMap and MutateSecret call newVaultClient in pkg/webhook/webhook.go, and vault.security.banzaicloud.io/vault-serviceaccount can cause a ServiceAccount JWT to be sent to a...
CVE-2026-82107	9.6	CRIT		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-87438	9.6	CRIT		0.006	google:android, google:chrome	Out of bounds write in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87448	9.6	CRIT		0.005	google:chrome	Use after free in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87455	9.6	CRIT		0.004	google:chrome	Use after free in Aura in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87464	9.6	CRIT		0.006	google:chrome	Use after free in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87470	9.6	CRIT		0.004	apple:macos, google:chrome	Improper quantity validation in Tint in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87474	9.6	CRIT		0.005	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87488	9.6	CRIT		0.005	google:android, google:chrome	Use after free in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87492	9.6	CRIT		0.003	google:chrome	Incorrect authorization in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87500	9.6	CRIT		0.003	google:chrome	Improper validation of array index in ANGLE in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87504	9.6	CRIT		0.004	google:chrome	Use after free in Core in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-87512	9.6	CRIT		0.005	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87520	9.6	CRIT		0.004	google:android, google:chrome	Use after free in Dawn in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87526	9.6	CRIT		0.004	google:chrome	Use after free in Passwords in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: Medium)
CVE-2026-87527	9.6	CRIT		0.005	google:chrome	Buffer overflow in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87528	9.6	CRIT		0.003	google:chrome, microsoft:windows	Type confusion in Rust in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87529	9.6	CRIT		0.005	google:chrome	Numeric truncation error in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87547	9.6	CRIT		0.004	google:chrome	Incorrect reference resolution in FileSystem in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87558	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Payments in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87581	9.6	CRIT		0.004	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87607	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Device in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87609	9.6	CRIT		0.004	apple:iphone_os, google:chrome	Use after free in Sharing in Google Chrome on on iOS prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87621	9.6	CRIT		0.003	google:chrome, microsoft:windows	Out of bounds write in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87634	9.6	CRIT		0.004	google:chrome	Use after free in WebPackaging in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87637	9.6	CRIT		0.003	apple:macos, google:chrome	Use after free in Extensions in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87638	9.6	CRIT		0.003	google:chrome	Out of bounds write in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87643	9.6	CRIT		0.004	google:android, google:chrome	Integer overflow in GPU in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87646	9.6	CRIT		0.004	google:chrome	Use after free in Web Authentication in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87650	9.6	CRIT		0.003	google:chrome	Out of bounds read in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87654	9.6	CRIT		0.004	google:chrome, microsoft:windows	Buffer overflow in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-44950	9.5	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) copies each glyph's bitmap into a single buffer. Existing checks validates only that the source slice (position, length) lies within the source bitmap buffer. It does not check whether the running destination cursor has exceeded the allocation. A malicious font server can send overlapping source offsets -- for example 1000 glyphs each referenc...
CVE-2026-65639	9.5	CRIT		0.016		OS command injection in the advanced-rule parser of ConfigServer Security & Firewall allows a remote attacker who controls a configured allow/deny feed to execute arbitrary commands as root, due to insufficient validation of feed-supplied rule data. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnera...
CVE-2026-66066	9.5	CRIT		0.279		Action Pack is a framework for handling and responding to web requests. In versions prior to 7.2.3.2, 8.0.5.1 and 8.1.3.1, Active Storage does not disable libvips operations marked unsafe for untrusted content, allowing a crafted upload to invoke such an operation. Consuming applications are affected when configured to use libvips and accept image uploads from untrusted users. An unauthenticated attacker may explo...
CVE-2026-85216	9.5	CRIT		0.005	misp-project:misp	MISP contains an authentication bypass vulnerability in its LDAP and LinOTP authentication components due to insufficient validation of user-supplied credentials. The custom LdapAuthenticate and LinOTPAuthenticate components replace CakePHP's FormAuthenticate implementation but did not replicate its credential validation checks. As a result, empty or non-string values could reach the underlying authentication mec...
CVE-2026-88062	9.5	CRIT		0.009		OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called refreshAgentCache, and resolveVersionProbe...
CVE-2026-81046	9.4	CRIT		0.004	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-82533	9.4	CRIT		0.006		DeepSeek Harness before 0.1.2-alpha.1 contains an authentication bypass vulnerability that grants unauthenticated access to its local HTTP agent-control API by accepting a client-supplied loopback Host header in place of validating the actual TCP connection origin. On the default configuration, a confined tool-executed process can reach the loopback API without any port exposure and use it to escape its own OS san...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84200	9.4	CRIT		0.002		Kyverno versions v1.9.0 through v1.12.7 contain a policy exception handling flaw. When a policy in enforce mode is combined with two PolicyExceptions, the less restrictive exception takes precedence, allowing an attacker to bypass the policy by crafting a resource name that matches the second exception's name pattern (e.g., *ingress*). This can be used to circumvent policies such as one blocking hostPath volumes...
CVE-2026-88285	9.4	CRIT		0.003		GeoVision GV-LPC2211 V1.13 exposes a network-accessible PTZ control service without authentication, allowing remote clients to retrieve PTZ information and issue PTZ or raw serial commands.
CVE-2023-54356	9.3	CRIT		0.001		Kyverno versions 1.9.4 and earlier support insecure 3DES cipher suites (TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA and TLS_RSA_WITH_3DES_EDE_CBC_SHA) on their TLS endpoints. These 64-bit block ciphers are vulnerable to the Sweet32 attack (CVE-2016-2183), which, over very long-lived TLS connections carrying large volumes of traffic, could allow an attacker to recover small amounts of plaintext. The issue is fixed in Kyver...
CVE-2026-25896	9.3	CRIT		0.005	naturalintelligence:fast-xml-parser	fast-xml-parser allows users to validate XML, parse XML to JS object, or build XML from JS object without C/C++ based libraries and no callback. From 4.1.3to before 5.3.5, a dot (.) in a DOCTYPE entity name is treated as a regex wildcard during entity replacement, allowing an attacker to shadow built-in XML entities (<, >, &, ", ') with arbitrary values. This bypasses entity encoding and leads ...
CVE-2026-44402	9.3	CRIT		0.009		Voltronic Power SNMP Web Pro 1.1 contains an unauthenticated remote code execution vulnerability in the upload.cgi firmware update endpoint that allows remote attackers to execute arbitrary commands as root by uploading a crafted tar archive without valid credentials. Attackers can supply a malicious tar archive containing arbitrary executable files that are extracted to a privileged directory and executed as root...
CVE-2026-44990	9.3	CRIT		0.006		ApostropheCMS is an open-source Node.js content management system, and sanitize-html provides a simple HTML sanitizer with a clear API. Under the default configuration, versions of `sanitize-html` prior to 2.17.4 can turn attacker-controlled content inside a disallowed `xmp` element into live HTML or JavaScript. This is a sanitizer bypass in the default `disallowedTagsMode: 'discard'` path and can lead to stored X...
CVE-2026-4599	9.3	CRIT		0.005	kjur:jsrsasign	Versions of the package jsrsasign from 7.0.0 and before 11.1.1 are vulnerable to Incomplete Comparison with Missing Factors via the getRandomBigIntegerZeroToMax and getRandomBigIntegerMinToMax functions in src/crypto-1.1.js; an attacker can recover the private key by exploiting the incorrect compareTo checks that accept out-of-range candidates and thus bias DSA nonces during signature generation.
CVE-2026-47156	9.3	CRIT		0.005		MantisBT is an open source bug tracker. Versions 2.28.3 and earlier contain a critical authentication bypass in the SOAP API's mci_check_login() function. Any user knowing any valid cookie_string can authenticate as any other user (knowing their username), including the administrator, without knowing the target's password. The vulnerability is exploitable with zero prior access on default MantisBT installations be...
CVE-2026-48063	9.3	CRIT		0.002		Baileys is a cocket-based TS/JavaScript API for WhatsApp Web. In versions prior to both 6.7.22 and 7.0.0-rc12, any Baileys session can be sent a malicious payload via the placeholderResendMessage and trigger a fake messages.upsert event with a fake message key and payload. This allows anyone to spoof messages. The same exploit also allows an attacker to corrupt the app state sync system by sending fake key shares...
CVE-2026-67531	9.3	CRIT		0.006		FrontMCP is a TypeScript-first framework for the Model Context Protocol (MCP). Prior to 1.5.7, the sandboxed codecall:execute tool exposes live host Zod schema instances to the script via getTool(), and because Zod v4 defines _zod as a non-configurable, non-writable own property, the ECMAScript Proxy invariants force the security membrane to hand back the raw host object, letting a script reach _zod.constr.constru...
CVE-2026-69356	9.3	CRIT		0.007		Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Exchange Server allows an unauthorized attacker to perform spoofing over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73665	9.3	CRIT		0.003		FreePBX is an open source IP PBX. Prior to 17.0.9, the UCP Node server on ports 8001 and 8003 uses io.use(checkAuth) in node/lib/server.js, but Socket.IO version 4 applies that middleware only to the default namespace. An unauthenticated client can connect to custom namespaces that do not consistently invoke checkAuth in node/lib/auth.js and send crafted event values containing carriage-return or newline character...
CVE-2026-75940	9.3	CRIT		0.003		A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.
CVE-2026-78082	9.3	CRIT		0.005		Joomla Extension - joomshaper.com - Unauthenticated SQL Injection in Property Search and Map Filtering in SP Property < 4.1.4 - The property search and listing query builders assembled several WHERE and ORDER BY clauses (zipcode, sorting, price_range_dropdown, and psize_range_dropdown) by directly concatenating raw request parameters into SQL strings without quoting or type casting. An unauthenticated remote attac...
CVE-2026-79782	9.3	CRIT		0.001		rcclone before 1.74.4 fails to strip the X-Amz-Security-Token header when an S3 redirect changes scheme from HTTPS to HTTP on the same host. Attackers can intercept plaintext HTTP traffic to capture AWS STS session tokens sent in request headers.
CVE-2026-80428	9.3	CRIT		0.023		ILIAS before versions 9.22, 10.10, and 11.3 contains an unauthenticated PHP object injection vulnerability that allows unauthenticated attackers to execute arbitrary code by injecting serialized objects through the LTI authentication endpoint and triggering deserialization via the Shibboleth back-channel logout endpoint. Attackers can write arbitrary serialized objects into session storage, then exploit an availab...
CVE-2026-81800	9.3	CRIT		0.002		Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-82854	9.3	CRIT		0.011		Nodemailer before 8.0.4 is vulnerable to SMTP command injection through the unsanitized envelope.size parameter. When an application passes a custom envelope object with a size property containing CRLF characters to sendMail(), the value is concatenated into the SMTP MAIL FROM command (as SIZE=...) without sanitization, allowing injection of arbitrary SMTP commands such as RCPT TO to silently add attacker-controll...
CVE-2026-82859	9.3	CRIT		0.003		hulumi versions before v1.3.2 contain a deployment SCP template that allows tag-on-create bypasses for hulumi:iac-role protections. Attackers can bypass intended IAM boundary restrictions by exploiting the weakened SCP template in downstream deployments.
CVE-2026-82876	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware verifies RSA signatures using a public modulus embedded within the firmware image itself rather than anchored in immutable storage. Attackers can generate arbitrary RSA key pairs, sign modified firmware with the private key, embed the matching modulus in the signature segment, and the controller accepts the tampered firmware as valid.
CVE-2026-8323	9.3	CRIT		0.003		URL redirection to untrusted site ('open redirect') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows Fake the Source of Data. This issue affects Access Control System: before Versiyon 2.
CVE-2026-84696	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware versions through SBFQT1.3 expose privileged vendor unique commands over the ATA interface with absent or defeatable authentication mechanisms. Attackers can bypass the weak CRC-16 based unlock handshake or exploit builds with no VUC lock to read and write controller memory and raw flash, persisting implants across power cycles.
CVE-2026-85183	9.3	CRIT		0.002		Taipy configures its socket.io server with wildcard CORS origin and credential flag enabled, allowing any web page to establish credentialed WebSocket connections to victim applications. Attackers can open socket.io sessions from arbitrary domains and invoke state variable modifications and action callbacks without CSRF protection.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85663	9.3	CRIT		0.005		Aim 3.29.1 remote tracking server fails to authenticate requests and dispatches arbitrary methods through getattr without allowlist validation. Unauthenticated attackers can register clients, instantiate Repo resources, and invoke arbitrary methods to read experiments or delete runs.
CVE-2026-85667	9.3	CRIT		0.004		xiaobei through 5.5.2 fails to implement authentication or signature validation on webhook endpoints, allowing unauthenticated attackers to inject arbitrary messages into the agent pipeline. Attackers can publish malicious messages via the /webhook_worktool handler and exploit unvalidated media URL fetching to perform server-side request forgery against internal services.
CVE-2026-85695	9.3	CRIT		0.004		FastChat contains an authentication bypass vulnerability in the /register_worker endpoint that allows unauthenticated attackers to register arbitrary worker addresses and perform server-side request forgery. Attackers can register malicious workers under victim model names to intercept user prompts, images, and responses, or probe internal network ports across the worker mesh.
CVE-2026-85696	9.3	CRIT		0.015		SadTalker contains an OS command injection vulnerability in the video muxing process where uploaded audio filenames are interpolated into ffmpeg commands without proper escaping. Attackers can upload audio files with shell metacharacters in the filename to break out of quoted arguments and execute arbitrary system commands when video generation occurs.
CVE-2026-88069	9.3	CRIT		0.003		Pandora contains a path traversal vulnerability in its archive extraction worker. When processing a specially crafted archive or disk image, attacker-controlled file paths could be used without ensuring that the resulting destination remained within the intended extraction directory. An attacker able to submit a malicious file for analysis could use path traversal sequences or crafted paths to cause extracted con...
CVE-2026-88860	9.3	CRIT		0.002		Capgo fails to clean up channel permission overrides when a user's last organization role binding is deleted, leaving stale overrides active. Attackers can retain channel-specific permissions after their base RBAC access has been revoked to perform unauthorized actions like changing production OTA versions.
CVE-2026-88864	9.3	CRIT		0.003		Capgo (capgo.app) fails to restrict direct write access to the public.sso_providers table exposed through Supabase PostgREST. A holder of an ordinary Capgo full API key can insert a row with status='active' and enforce_sso=true, bypassing the intended backend SSO provisioning route (supabase/functions/_backend/private/sso/providers.ts) and its controls: the Enterprise plan requirement, SSO provider creation via th...
CVE-2026-88866	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the Login History page, allowing script execu...
CVE-2026-88867	9.3	CRIT		0.003		WWBN AVideo, in versions up to and including commit c3edcc274c389816d434acadac07ee78eaf330c1, contains a stored cross-site scripting vulnerability. objects/categoryAddNew.json.php passes the POST parameters `name` and `iconClass` to Category::setName() and Category::setIconClass(), which store the values without sanitization (setName only truncates to 45 characters). The category name is later echoed as HTML text ...
CVE-2026-88868	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LiveLinks plugin where title and description fields are stored without sanitization. A user with canStream permission can inject malicious scripts that execute in the browser of every visitor viewing the live-link page, including administrators, within the site origin.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88869	9.3	CRIT		0.005		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the AD_Server plugin's log.php endpoint that fails to escape the label parameter before storage. An unauthenticated attacker can inject malicious HTML through the label parameter, which is later rendered unsanitized in the admin Ad Types report using jQuery .html(), allowing execution of arbitrary...
CVE-2026-88877	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only the RedirectRegex middleware, and still...
CVE-2026-88899	9.3	CRIT		0.004		knowns versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89042	9.3	CRIT		0.003		passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-13745	9.2	CRIT		0.003		A vulnerability in the Gemini CLI and associated GitHub Action allowed an unprivileged attacker to achieve an arbitrary code execution in Gemini CLI via untrusted local .env files overriding GEMINI_CLI_HOME.
CVE-2026-59679	9.2	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) indexes the per-character encoding[] array using num_chars from the FS_QueryXBitmaps16 reply, but that array was allocated with a size derived from num_extents in the separate FS_QueryXExtents16 reply. The two CARD32 fields are never cross-checked. A malicious or compromised font server can send a small num_extents (e.g. 1) in the extents reply...
CVE-2026-65638	9.2	CRIT		0.032		Improper escaping of a request URL in ConfigServer Security & Firewall allows an unauthenticated remote attacker to execute arbitrary commands as the CSF service account via shell command injection. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnerable code. WebPros has addressed the vulnerability ...
CVE-2026-85694	9.2	CRIT		0.005		LaVague 0.2.35 contains a remote code execution vulnerability in PythonFromMarkdownExtractor.extract_as_object that evaluates untrusted language model output derived from web page content. Attackers can inject malicious Python code through web pages using indirect prompt injection to execute arbitrary code on the operator's host without review.
CVE-2026-86117	9.2	CRIT		0.004		Coolify through 4.3.17 contains an authentication bypass vulnerability in the OAuth callback handler that signs users into existing accounts based solely on email address without verifying provider assertions or binding OAuth identities. Attackers can register a victim's email address on any enabled OAuth provider to obtain authenticated sessions as that user, bypassing password requirements and two-factor authentic...
CVE-2026-88880	9.2	CRIT		0.004		Renovate before 44.11.3 fails to validate Link header destinations when following GitLab server pagination, allowing malicious servers to redirect credential-bearing requests. Attackers controlling a compromised GitLab server can specify a Link header pointing to attacker-controlled infrastructure to exfiltrate authentication credentials.
CVE-2026-88881	9.2	CRIT		0.003		Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the `next` page. Because the pagination URL is not validated against the host originally contacted, a malicious or compromised GitHub server ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88882	9.2	CRIT		0.003		Renovate is a dependency update automation tool. In versions before 44.11.2 (and Mend Renovate CE/EE images and charts before 15.4.0, and mend-renovate-enterprise-edition helm chart before 10.4.0), when listing new package versions from a NuGet registry Renovate follows pagination URLs supplied by the registry in the HTTP `Link` header without verifying that the target has the same origin as the configured registr...
CVE-2026-88887	9.2	CRIT		0.003		Renovate is a dependency update automation tool. When listing tags/digests for a container image, Renovate follows pagination links supplied by the remote registry in the HTTP Link header and attaches the registry credentials to the follow-up request without verifying that the pagination URL has the same origin as the original registry. A malicious or compromised container registry can therefore specify a Link hea...
CVE-2025-49794	9.1	CRIT		0.008		A use-after-free vulnerability was found in libxml2. This issue occurs when parsing XPath elements under certain circumstances when the XML schematron has the <sch:name path="..."> schema elements. This flaw allows a malicious actor to craft a malicious XML document used as input for libxml, resulting in the program's crash using libxml or other possible undefined behaviors.
CVE-2025-49796	9.1	CRIT		0.015		A vulnerability was found in libxml2. Processing certain sch:name elements from the input XML file can trigger a memory corruption issue. This flaw allows an attacker to craft a malicious XML input file that can lead libxml to crash, resulting in a denial of service or other possible undefined behavior due to sensitive data being corrupted in memory.
CVE-2026-19646	9.1	CRIT		0.005		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-2332	9.1	CRIT		0.013	eclipse:jetty	In Eclipse Jetty, the HTTP/1.1 parser is vulnerable to request smuggling when chunk extensions are used, similar to the "funky chunks" techniques outlined here: * https://w4ke.info/2025/06/18/funky-chunks.html * https://w4ke.info/2025/10/29/funky-chunks-2.html Jetty terminates chunk extension parsing at \r\n inside quoted strings instead of treating this as an error. POST / HTTP/1.1 Host: localhost Tr...
CVE-2026-27962	9.1	CRIT		0.005	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. Prior to version 1.6.9, a JWK Header Injection vulnerability in authlib's JWS implementation allows an unauthenticated attacker to forge arbitrary JWT tokens that pass signature verification. When key=None is passed to any JWS deserialization function, the library extracts and uses the cryptographic key embedded in the attacker-controlled J...
CVE-2026-41869	9.1	CRIT		0.008	apache:nutch	Missing Authorization, Improper Resource Shutdown and Job Interruption vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted users only. Please, also visit the Ap...
CVE-2026-42044	9.1	CRIT		0.006	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. From 1.0.0 to before 1.15.2, he Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution in the application's dependency tree to be escalated into surgical, invisible modification of all JSON API responses — including privilege escalation, balance manipulation, and authorization bypass. The defa...
CVE-2026-45764	9.1	CRIT		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workaround, disable HTTP/2 parsing if it is not ...
CVE-2026-48031	9.1	CRIT		0.004		go-base is a Go RESTful API Boilerplate template with JWT Authentication, backed by PostgreSQL. In versions prior to 2026-05-18, the JWT signing secret is hardcoded to the known string "random", letting any attacker who reads the public repository forge tokens for arbitrary users, including admin roles, and completely bypass authentication on all protected endpoints. This value is set in two places: the dev.env te...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-48039	9.1	CRIT		0.004		Meta Ads MCP is a Model Context Protocol (MCP) server that lets AI assistants run Meta Ads. Prior to version 1.0.109, `AuthInjectionMiddleware.dispatch()` at `http_auth_integration.py:272` unconditionally forwards unauthenticated Streamable HTTP requests to downstream MCP tool handlers without issuing a `401` response, allowing any network-reachable caller to invoke MCP tools without authentication. When no per-re...
CVE-2026-49364	9.1	CRIT		0.004	apache:artemis	An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-53939	9.1	CRIT		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). In versions 0.6.1 through 0.6.2.5, when cjose encrypts a JWE using an AES-CBC-HMAC content-encryption algorithm (`A128CBC-HS256`, `A192CBC-HS384`, or `A256CBC-HS512`) together with any key-management algorithm that generates a fresh content-encryption key (CEK), the CEK is all zero bytes instead of being randomly generat...
CVE-2026-62646	9.1	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A session identifier is generated using an algorithm with insufficient randomness, resulting in a token with low entropy that can be predicted or brute-forced within a feasible number of attempts. This could allow an unauthenticated remote attacker to derive valid session identifiers and bypass authentication.
CVE-2026-67593	9.1	CRIT		0.006	apache:artemis	A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-68006	9.1	CRIT		0.004		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file
CVE-2026-71640	9.1	CRIT		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline
CVE-2026-78361	9.1	CRIT		0.003		The zipMoney(Zip Co) Payments Plugin for WooCommerce WordPress plugin before 2.4.0 does not perform any authorisation checks on one of its front-end request handlers, and does not restrict which option name a caller may supply, allowing unauthenticated users to delete arbitrary WordPress options. This can be used to destroy site and access control configuration, deactivate every installed zipMoney(Zip Co) Payments...
CVE-2026-80424	9.1	CRIT		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-84939	9.1	CRIT		0.008	apache:freemarker	Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling localized lookup in previous versions also...
CVE-2026-86729	9.1	CRIT		0.002		WWBN AVideo through commit e01e41ecc (no patched version available) exposes get_api_preauthorize in plugin/API/API.php as a second, undocumented login path. Unlike get_api_signIn, which enforces a rate limit of 10 attempts per 5 minutes via checkRateLimit(), get_api_preauthorize performs the same credential check with no throttling for any client, allowing unlimited remote password guessing against arbitrary accou...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86840	9.1	CRIT		0.002		The `vtoken-minting` and `slpx` pallets in Bifrost contain an improper authorization vulnerability in channel commission attribution. A signed account can supply an arbitrary registered `channel_id` when minting tokens without verifying that the caller is authorized to mint on behalf of that channel. This allows an attacker to inflate a channel's recorded mint volume and cause protocol commission payments to be di...
CVE-2026-87806	9.1	CRIT		0.003		Parse Server versions <= 8.6.87 and >= 9.0.0 < 9.10.1-alpha.7 contain an authentication bypass in the built-in LDAP authentication adapter. The adapter forwarded the client-supplied password to the directory without verifying that a password had been supplied, and treated any non-error response from the directory as proof of authentication. A zero-length credential turns an LDAP simple bind into the unauthenticate...
CVE-2026-88007	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backend keep-alive, an unr...
CVE-2026-88044	9.1	CRIT		0.005		rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.70.0 until 1.75.1, the serve/start RC interface accepts per-server proxyOpt.AuthProxy settings, and the FTP and S3 constructors in cmd/serve/ftp/ftp.go and cmd/serve/s3/server.go incorrectly check the process-global proxy.Opt.AuthProxy value instead. When the global value is empty, the request-local...
CVE-2026-89043	9.1	CRIT		0.003		passport-saml-encrypted through 0.1.13 contains an XML signature wrapping vulnerability where signature verification and assertion extraction use independent XPath lookups with no cross-validation. Attackers holding any validly signed SAML message can prepend a forged unsigned assertion that gets accepted as the verified identity while the genuine signature validates against the original assertion.
CVE-2026-89086	9.1	CRIT		0.002		In the jose package before 0.11.0 for OCaml, library calls to validate an RSA signature only confirm that PKCS #1 decoding succeeds, and proceed to declare the signature valid without the required steps that involve the public key.
CVE-2026-85982	9.0	CRIT		0.002		The Auth0 AD/LDAP Connector is vulnerable to stored Cross-Site Scripting (XSS) issues due to improper HTML encoding of data in search results and updater log content displayed in the admin panel. An authenticated user with privileges to modify directory attributes, or a low-privileged local user on the host where the connector is installed, could insert script content. This script content could then execute in an ...
CVE-2026-86259	9.0	CRIT		0.003		OpenMAIC before 1.0.1 skips server-side request forgery validation in non-production builds, allowing unauthenticated attackers to reach cloud instance metadata services. Attackers can supply arbitrary provider URLs via the x-base-url header or baseUrl parameter to access sensitive cloud credentials and metadata.
CVE-2026-87613	9.0	CRIT		0.004	google:chrome	Incorrect reference resolution in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87911	9.0	CRIT		0.01		An OS command injection weakness in the read-only enforcement of the SQL validation component in Amazon awslabs postgres-mcp-server before 1.1.7 might allow an unauthenticated actor to execute operating system commands on the host of a self-managed PostgreSQL server by placing a crafted COPY ... TO PROGRAM statement into content that is processed when an authenticated user interacts with the MCP server in its defa...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-44432	8.9	HIGH		0.007	python:urllib3	urllib3 is an HTTP client library for Python. From 2.6.0 to before 2.7.0, urllib3 could decompress the whole response instead of the requested portion (1) during the second HTTPResponse.read(amt=N) call when the response was decompressed using the official Brotli library or (2) when HTTPResponse.drain_conn() was called after the response had been read and decompressed partially (compression algorithm did not matte...
CVE-2026-5598	8.9	HIGH		0.009		Covert timing channel vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA core on all (core modules). This vulnerability is associated with program files FrodoEngine.Java. This issue affects BC-JAVA: from 1.71 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-19298	8.8	HIGH		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to execute arbitrary code due to an authorization bypass in the flow build process.
CVE-2026-27606	8.8	HIGH		0.015	rollupjs:rollup	Rollup is a module bundler for JavaScript. Versions prior to 2.80.0, 3.30.0, and 4.59.0 of the Rollup module bundler (specifically v4.x and present in current source) is vulnerable to an Arbitrary File Write via Path Traversal. Insecure file name sanitization in the core engine allows an attacker to control output filenames (e.g., via CLI named inputs, manual chunk aliases, or malicious plugins) and use traversal ...
CVE-2026-28666	8.8	HIGH		0.003		In multiple functions of LocalImageResolver.java, there is a possible Remote Persistent Denial of Service due to a DNG image rendering check bypass. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-57866	8.8	HIGH		0.006	apache:impala	Server side request forgery in Apache Impala versions 4.4.x and 4.5.x. Authenticated Impala users with permissions to execute the ai_generate_text() function can exfiltrate secrets provided by the credential providers configured in the `hadoop.security.credential.provider.path` property of `core-site.xml`. The secret's key must be known to the user.
CVE-2026-62895	8.8	HIGH		0.007		Permissive cross-domain policy with untrusted domains in Azure Arc allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-64364	8.8	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: HID: multitouch: fix out-of-bounds bit access on mt_io_flags mt_io_flags is a single unsigned long, but mt_process_slot(), mt_release_pending_palms() and mt_release_contacts() use it as a per-slot bitmap indexed by the slot number. That slot number is only bounded by td->maxcontacts, which is taken from the device's ContactCountMaximum feature r...
CVE-2026-69499	8.8	HIGH		0.008		Integer overflow or wraparound in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-69529	8.8	HIGH		0.005	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69547	8.8	HIGH		0.009		Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over a network.
CVE-2026-69551	8.8	HIGH		0.009		Use after free in Windows DNS allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69614	8.8	HIGH		0.009	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Stack-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69729	8.8	HIGH		0.009		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to execute code over a network.
CVE-2026-69778	8.8	HIGH		0.008	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-71808	8.8	HIGH		0.004		A SQL Injection vulnerability in Siam Ordering (siam-server) 1.0.0 allows remote authenticated attackers to execute arbitrary SQL commands via the \${} string concatenation in AdminMapper.java and multiple other Mapper files (including MerchantWithdrawRecordMapper.java and MemberWithdrawRecordMapper.java).
CVE-2026-73006	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73016	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-75624	8.8	HIGH		0.004	ibm:aix, ibm:app_connect_enterprise, linux:linux_kernel, microsoft:windows	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.27 could allow a remote authenticated attacker to bypass security restrictions due to incorrect authorization.
CVE-2026-75777	8.8	HIGH		0.001		IBM Aspera Enterprise WebApps 1.0.0 through 1.0.5 could allow a local attacker to escape container protections due to unrestricted system calls being permitted within the container.
CVE-2026-76059	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 An attacker who could submit custom component source code could bypass the static security scanner by crafting an annotated class-body assignment that resolved to a dangerous callable through alias tracking; the resolved value was never checked against the dangerous callable blacklist due to the logic error. If the crafted component reached the runtime execution path, the atta...
CVE-2026-77907	8.8	HIGH		0.005	microsoft:visual_studio_2026	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-78569	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to execute arbitrary code due to an incomplete denylist in the security scanner.
CVE-2026-78571	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an unguarded eval() call on attacker-controlled input.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78575	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary commands due to improper validation of command-line arguments in the MCP stdio server configuration.
CVE-2026-79742	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an incomplete environment variable blacklist.
CVE-2026-80083	8.8	HIGH		0.002	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-80096	8.8	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-80921	8.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: KVM: s390: vsie: zero stale crypto bits When shadowing crypto access bits from a format0 apcb (crycb 0 or 1), the bits 64..255 are unchanged from whatever is in the vsie page in the crycb and thus in the apcb. This gives a nested guest potential access to a device no longer available. Zero out the remaining bits.
CVE-2026-81211	8.8	HIGH		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary Python code due to improper authorization of custom components in stored flows.
CVE-2026-81550	8.8	HIGH		0.006	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-81940	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special characters in flow display names.
CVE-2026-81941	8.8	HIGH		0.008	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 allows an authenticated non-administrative user could execute arbitrary operating system commands on the server at the privilege level of the application process by constructing a flow with an MCP Tools component configured to use a local stdio subprocess transport. This bypasses both the LANGFLOW_CUSTOM_COMPONENT_ADMIN_ONLY and LANGFLOW_BLOCK_CODE_INTERPRETER_COMPONENTS serve...
CVE-2026-81996	8.8	HIGH		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82095	8.8	HIGH		0.006	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-82097	8.8	HIGH		0.004	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to a Server-Side Request Forgery (SSRF) vulnerability.
CVE-2026-82098	8.8	HIGH		0.008	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-82099	8.8	HIGH		0.004	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83992	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-84889	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.10.3 could allow a remote authenticated attacker to execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-85228	8.8	HIGH		0.004		An integer overflow in the tensor buffer validation component in Amazon Deep Java Library (DJL) from 0.13.0 through 0.36.0 on all platforms might allow a remote unauthenticated actor to obtain information from adjacent process memory or cause a denial of service via a crafted tensor payload. To remediate this issue, users should upgrade to version 0.37.0 or above.
CVE-2026-87585	8.8	HIGH		0.003	google:chrome, microsoft:windows	Double free in PDFium in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code inside the sandbox via a crafted PDF file. (Chromium security severity: High)
CVE-2026-10143	8.7	HIGH		0.005	dpkp:kafka-python	kafka-python prior to 2.3.2 contains a denial-of-service vulnerability in SCRAM authentication handling that allows a malicious or machine-in-the-middle broker to freeze the client event loop by supplying an excessively large iteration count. In scram.py, ScramClient.process_server_first_message() passes the broker-controlled SCRAM iteration count directly to hashlib.pbkdf2_hmac() without validation, blocking prod...
CVE-2026-16174	8.7	HIGH		0.001		Netskope was notified about a potential gap in Netskope Endpoint DLP (EPDLP) running on Windows systems. Successful exploitation of the gap could potentially allow a privileged user to send a crafted message to the EPDLP process port to trigger an integer overflow, leading to memory corruption. Successful exploitation would require the EPDLP module to be enabled in the client configuration, and that Memory Integri...
CVE-2026-40192	8.7	HIGH		0.007	python:pillow	Pillow is a Python imaging library. Versions 10.3.0 through 12.1.1 did not limit the amount of GZIP-compressed data read when decoding a FITS image, making them vulnerable to decompression bomb attacks. A specially crafted FITS file could cause unbounded memory consumption, leading to denial of service (OOM crash or severe performance degradation). If users are unable to immediately upgrade, they should only open ...
CVE-2026-41674	8.7	HIGH		0.005		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) `DOMParser` and `XMLSerializer` module. In @xmldom/xmldom prior to versions 0.9.10 and 0.8.13 and xmldom version 0.6.0 and prior, the package serializes DocumentType node fields (internalSubset, publicId, systemId) verbatim without any escaping or validation. When these fields are set programmatically to attacker-controlled strings, XMLSerialize...
CVE-2026-47879	8.7	HIGH		0.003	vmware:spring_cloud_gateway	Spring Cloud Gateway JsonToGrpcGatewayFilterFactory allows arbitrary Spring Resource locations for defining the proto descriptor. Spring Cloud Gateway 5.0.0 - 5.0.2 Spring Cloud Gateway 4.3.0 - 4.3.5 Spring Cloud Gateway 4.0.0 - 4.2.9 Spring Cloud Gateway 3.1.13 and earlier
CVE-2026-54722	8.7	HIGH		0.004		DSSRF is a Node.js library that provides a wide range of utilities and advanced SSRF defense checks. Prior to 1.0.4, is_url_safe in src/helpers.ts strips the @ userinfo delimiter with remove_at_symbol_in_string before new URL parses the URL, allowing an attacker-controlled URL to bypass internal-IP validation and cause a client using the original URL to reach an internal service. This issue is fixed in version 1.0.4.
CVE-2026-54729	8.7	HIGH		0.004		DSSRF is a Node.js library that provides a wide range of utilities and advanced SSRF defense checks. Prior to 1.0.5, is_url_safe can treat localhost as safe when DNS resolver 1.1.1.1 returns NXDOMAIN because dns.resolve4 yields no address and no dns.lookup fallback occurs, allowing server-side request forgery. This issue is fixed in version 1.0.5.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55100	8.7	HIGH		0.004		hashi-vault-js is a Node.js module for interacting with the HashiCorp Vault API. Prior to 0.5.2, src/Vault.js concatenates unencoded identifier values including name, username, group, role, and version into Vault request paths and query strings instead of using encodeURIComponent() and URLSearchParams, allowing path traversal and query parameter injection. This issue is fixed in version 0.5.2.
CVE-2026-55250	8.7	HIGH		0.006		Maravel, a PHP framework oriented towards dependency injection, prior to version 10.74.0 has a high-severity Token Replay Vulnerability arising from a structural lifecycle mismatch between stateless token validation engines and high-performance relational caching layers. Any application with low cache memory that causes premature eviction to free up memory and applications running macropay-solutions/maravel-framew...
CVE-2026-59643	8.7	HIGH		0.002	bouncycastle:bc-java, bouncycastle:bcpg-fips	In Bouncy Castle for Java before 1.85, OpenPGP inline-signature policy failures silently ignored. This issue also affects Bouncy Castle for Java FIPS (BC-FJA) before bcpg-fips 2.0.13.
CVE-2026-62243	8.7	HIGH		0.002		Netty (io.netty:netty-handler) versions from 4.2.0.Final through 4.2.16.Final and versions through 4.1.136.Final disable TLS hostname verification on the SslProvider.OPENSsl client path when a plain (non-extended) X509TrustManager is used and Unsafe-based trust-manager wrapping is unavailable (Java 25+). In this configuration the OpenSSL client does not perform hostname verification, allowing a man-in-the-middle a...
CVE-2026-69220	8.7	HIGH		0.004		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.1, src/main/java/com/rabbitmq/client/impl/ValueReader.java permits ValueReader.readTable and ValueReader.readArray to call ValueReader.readFieldValue recursively for AMQP table type F and AMQP array type A values without a nesting-depth limit. A malicious AMQP server or network inte...
CVE-2026-69249	8.7	HIGH		0.003		python-cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. In versions 42.0.0 through 48.0.0, when resolving invalid certificate chains that include duplicate copies of self-signed certificates, the processing recursively invokes the same candidate, leading to an exponential blowup. Although the limitation that the chain depth cannot exceed a specified maximum de...
CVE-2026-84694	8.7	HIGH		0.005		Coolify before 4.2.0 fails to properly escape environment variable key names in Docker commands executed over SSH on managed servers. Authenticated attackers can inject shell metacharacters into environment variable keys to execute arbitrary commands on the server host outside containers.
CVE-2026-85610	8.7	HIGH		0.004		OpenPanel before 2.3.0 fails to properly validate chart formula expressions, allowing authenticated project members with read access to execute arbitrary code by recovering the native JavaScript Function constructor through mathjs matrix objects. Attackers can use the recovered constructor to load Node.js built-ins and execute operating system commands with the privileges of the API process, bypassing organization...
CVE-2026-85687	8.7	HIGH		0.003		surya 0.22.1 screenshot server contains an unauthenticated arbitrary file read vulnerability in the /info, /page, and /process routes that accept raw file_path parameters. Attackers can read any image or PDF file on the host by supplying arbitrary file paths to Image.open or pypdfium2.PdfDocument, obtaining rendered contents as base64 and using /info as an existence oracle.
CVE-2026-88874	8.7	HIGH		0.005		AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) does not enforce the Live stream password check on the stats endpoint or on the HLS origin. Live::_getStats() (plugin/Live/Live.php) returns a password-protected transmission's RTMP stream key, its isPasswordProtected flag, and its HLS (m3u8) URL to unauthenticated callers, in both the public applications list and the hidden_appl...
CVE-2026-25990	8.6	HIGH		0.004	python:pillow	Pillow is a Python imaging library. From 10.3.0 to before 12.1.1, an out-of-bounds write may be triggered when loading a specially crafted PSD image. This vulnerability is fixed in 12.1.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81213	8.6	HIGH		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to obtain sensitive information from internal network resources due to improper validation of user-supplied URLs.
CVE-2026-86712	8.6	HIGH		0.004		SiYuan before 3.8.2 trusts the attacker-writable text/siyuan clipboard MIME type and skips sanitization in the paste handler, allowing code execution in the Node-enabled desktop renderer. Attackers can craft malicious web pages that write to the clipboard, and when pasted into SiYuan, injected scripts execute with full Node.js access through the Electron main process.
CVE-2026-87794	8.6	HIGH		0.002		bestzip versions 2.2.6 and 3.0.2 contain an argument injection vulnerability in the nativeZip function that allows attackers to inject arbitrary arguments to the Info-ZIP backend. Attackers can supply a malicious destination path combined with crafted source entries to execute arbitrary commands with Node.js process privileges. Fixed in 2.2.7 and 3.0.3.
CVE-2026-88056	8.6	HIGH		0.004		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular Server-Side Rendering in @angular/platform-server processes user-controlled resource or request URLs through HttpClient after application code validates them with WHATWG URL parsing. The resolveUrl and parseUrl utilities called String.pro...
CVE-2026-88058	8.6	HIGH		0.005		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes ProcessingInstruction DOM nodes inside fallback raw-content elements without escaping matching ancestor closing tags. ProcessingInstruction data escaped greater-than chara...
CVE-2026-88060	8.6	HIGH		0.007		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes untrusted input inside template content nested in fallback raw-content elements such as noscript, iframe, noembed, and noframes. The Domino serializer's fallbackRawContent...
CVE-2026-6958	8.5	HIGH		0.001		Acunetix 25.11.251107123 for Windows contains a local privilege escalation vulnerability in the Web Vulnerability Scanning Engine (wvsc.exe) that allows low-privileged local attackers to execute arbitrary code as SYSTEM by exploiting a missing hardcoded directory path for OpenSSL-related files. Attackers can create the missing directory, place a malicious file at the expected path, and cause the SYSTEM-level wvsc....
CVE-2026-74860	8.5	HIGH		0.004		A flaw was found in libxml2 with Python bindings enabled. A remote attacker could exploit this vulnerability by providing a specially crafted XML document containing a Document Type Definition (DTD) with enumerated attribute values. This triggers a double-free error in the SAX attributeDecl callback handler, where a string is freed twice. This flaw can lead to a denial of service (DoS) due to a reproducible crash ...
CVE-2026-80436	8.5	HIGH		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service by deleting arbitrary RabbitMQ queues or exchanges due to improper authorization.
CVE-2026-81207	8.5	HIGH		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 allows any authenticated tenant — with no project membership or role — fully controls scheme/host/port/path of an outbound fetch originating from a shared-infrastructure pod, and the WSDL body is reflected verbatim to the caller. The ds-canvas pod sits on the OpenShift overlay with reach to co-tenant services, in-cluster CP4D APIs, and link-local addresses. Scope is Chan...
CVE-2026-81540	8.5	HIGH		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to overwrite ruleset files belonging to other tenants due to a path traversal vulnerability.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88886	8.5	HIGH		0.002		Renovate is a dependency update automation tool. In versions before 44.14.7 (and in Mend Renovate CE/EE distributions before 15.4.0, and the mend-renovate-enterprise-edition Helm chart before 10.4.0), the manager/gradle-wrapper module does not escape the distributionUrl value read from a repository's gradle/wrapper/gradle-wrapper.properties file before invoking the Gradle Wrapper CLI. In self-hosted deployments co...
CVE-2026-88889	8.5	HIGH		0.006		Renovate before 44.14.7 contains a command injection vulnerability in the Maven Wrapper manager that allows attackers to execute arbitrary commands by specifying a malicious distributionType parameter in maven-wrapper.properties. Attackers can inject shell commands through unescaped distributionType values to achieve remote code execution when Renovate processes Maven Wrapper updates in binarySource=docker mode.
CVE-2026-89049	8.5	HIGH		0.004		A server-side request forgery issue due to improper validation of equivalent address representations in the port forwarding to remote hosts functionality in Amazon AWS Systems Manager Agent (SSM Agent) before 3.3.4851.0 on all platforms might allow an authenticated remote user to bypass the remote destination denylist and reach link-local endpoints, potentially obtaining the temporary IAM role credentials of a man...
CVE-2026-88022	8.4	HIGH		0.003		Improper neutralization of special elements in data query logic in the MongoDB integration for Laravel can cause an array supplied to an explicit equality filter to be interpreted as a query condition rather than as a literal value. This affects the three-argument `where` method when the operator is `>=` or `eq`, as well as the `find` and `delete` methods that use that code path. An attacker who can cause an affect...
CVE-2026-88890	8.4	HIGH		0.003		OpenPanel through commit cd24bb8 contains an SQL injection vulnerability in the analytics filter builder that fails to validate profile.* filter column identifiers before interpolating them into ClickHouse WHERE clauses. An authenticated attacker with project-scoped read or root export credentials can inject arbitrary ClickHouse SQL to bypass project isolation and read other organizations' analytics data and profi...
CVE-2026-87524	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in Core in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87616	8.3	HIGH		0.004	google:chrome, microsoft:windows	Improper initialization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87618	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect reference resolution in Storage in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87644	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect authorization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87648	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-26007	8.2	HIGH		0.003	cryptography.io:cryptography	cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. Prior to 46.0.5, the public_key_from_numbers (or EllipticCurvePublicNumbers.public_key()), EllipticCurvePublicNumbers.public_key(), load_der_public_key() and load_pem_public_key() functions do not verify that the point belongs to the expected prime-order subgroup of the curve. This missing validation allows an a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28498	8.2	HIGH		0.002	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. Prior to version 1.6.9, a library-level vulnerability was identified in the Authlib Python library concerning the validation of OpenID Connect (OIDC) ID Tokens. Specifically, the internal hash verification logic (<code>_verify_hash</code>) responsible for validating the <code>at_hash</code> (Access Token Hash) and <code>c_hash</code> (Authorization Code Hash) claims exhibits a f...
CVE-2026-53938	8.2	HIGH		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). Prior to version 0.6.2.5, cjose's JWE decryption path for the AES Key Wrap key-management algorithms (<code>`alg` = `A128KW`, `A192KW`, `A256KW`</code>) does not validate the length of the attacker-supplied <code>`encrypted_key`</code> (JWE Encrypted Key) before unwrapping it into a fixed-size, heap-allocated Content Encryption Key (CEK) buffer. ...
CVE-2026-69247	8.2	HIGH		0.002		cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. From 44.0.0 until 50.0.0, <code>pkcs7_decrypt_der</code> , <code>pkcs7_decrypt_pem</code> , and <code>pkcs7_decrypt_smime</code> reported the outcome of decrypting a <code>RecipientInfo</code> 's <code>encryptedKey</code> in several distinguishable ways, one of which disclosed the exact length recovered from the RSA operation. The same distinction was also observable by timing. ...
CVE-2026-81354	8.2	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-83939	8.2	HIGH		0.003	microsoft:windows_11_26h1	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-86253	8.2	HIGH		0.004		h3 (npm package) versions <code><= 2.0.1-rc.14</code> contain a path traversal vulnerability in <code>serveStatic()</code> . On Node.js deployments, <code>event.url.pathname</code> is not normalized, so percent-encoded dot segments (<code>%2e%2e</code>) are passed to <code>decodeURI()</code> and decoded to <code>../</code> sequences without sanitization. An unauthenticated remote attacker can send crafted requests to endpoints served by <code>serveStatic()</code> to read arbitrary files outside the inten...
CVE-2026-86600	8.2	HIGH		0.003		In affected Snowflake drivers, <code>WORKLOAD_IDENTITY</code> authentication requests a cloud workload-identity token and attaches it to the login request without verifying that the configured host is a Snowflake endpoint. An attacker who can modify the connection configuration can cause the driver to mint a fresh attestation and send it to a host they control. The captured token can be replayed to Snowflake for its remaining ...
CVE-2026-88032	8.2	HIGH		0.002	mongodb:java_driver	A use-after-free in the reactive client-side encryption component of the MongoDB Java Driver can cause native resources to be freed while an affected encrypted operation is still using them when the operation is cancelled. A party able to cause such an operation to be cancelled may cause the hosting application process to terminate. Reaching the issue requires an affected reactive encryption configuration that ret...
CVE-2026-89054	8.2	HIGH		0.004		A missing authorization vulnerability in OpenNMS Horizon allows configuration changes without authentication. The Spring Security policy for the <code>/api/v2</code> REST API defines authorization rules for every HTTP method except <code>PATCH</code> , so the shipped <code>@PATCH</code> configuration endpoints for event configuration and SNMP data collection (which enable and disable event definitions and data-collection sources) are reachable with no a...
CVE-2026-18147	8.1	HIGH		0.003		A flaw was found in FreeIPA. An unauthenticated remote attacker could exploit a DOM Cross-Site Scripting (XSS) vulnerability in the FreeIPA/IdM Web UI password reset page. By enticing a victim to click a specially crafted link and complete a password reset, the attacker could inject and execute arbitrary JavaScript code. This allows the attacker to perform actions within the victim's authenticated session, potenti...
CVE-2026-19303	8.1	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to delete arbitrary local files or directories due to improper limitation of a pathname to a restricted directory.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-65181	8.1	HIGH		0.006	apache:impala	Insufficient authorization of Data Source tables in Impala 2.7-4.5 allows a client with privileges to upload a file to remote storage and create a table to execute arbitrary Java code. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-69620	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69680	8.1	HIGH		0.003		Origin validation error in Windows DNS allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-72987	8.1	HIGH		0.006		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-73334	8.1	HIGH		0.004	apache:parquet	Potential problem for users of the org.apache.parquet.crypto.keytools package in Apache Parquet, versions 1.12 to 1.18. This package enables users to encrypt Parquet files via an envelope encryption mechanism that wraps (encrypts) data keys via a Key Management Service (KMS). On the reader side, the KMS URL can be application-controlled or file-controlled. If the user does not leverage application control for th...
CVE-2026-78626	8.1	HIGH		0.002		The Okta Access Gateway improperly handles input sanitization and regular expression evaluation within its Protected Rule authorization check, resulting in an authorization bypass when an administrator has explicitly configured a Protected Rule policy on one or more application resources.
CVE-2026-80354	8.1	HIGH		0.003	apache:camel	Authorization bypass through User-Controlled key vulnerability in Apache Camel K. An authorization vulnerability in custom resource resolution allows a tenant to reference secrets by name in the operator namespace, potentially exposing secrets belonging to other tenants or operator components. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users are recommended to u...
CVE-2026-81268	8.1	HIGH		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute flows and obtain sensitive information due to insufficient session expiration of API keys after user deactivation.
CVE-2026-81551	8.1	HIGH		0.005	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to arbitrarily write to or delete files on shared storage due to a path traversal vulnerability.
CVE-2026-84393	8.1	HIGH		0.002		A improper validation of certificate with host mismatch vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6, FortiProxy 7.6.2 through 7.6.6 may allow attacker to information disclosure via <insert attack vector here>
CVE-2026-87457	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-87467	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to potentially execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-87509	8.1	HIGH		0.001	google:chrome, microsoft:windows	Incorrect authorization in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Low)
CVE-2026-87530	8.1	HIGH		0.001	google:chrome, microsoft:windows	Uncontrolled search path element in CredentialProvider in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-87554	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87958	8.1	HIGH		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-9327	8.1	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.
CVE-2026-69322	8.0	HIGH		0.007		Double free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69481	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Enterprise App Management allows an authorized attacker to elevate privileges over a network.
CVE-2026-69847	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69876	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-16826	7.8	HIGH		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-17523	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: can: bcm: switch timer to HRTIMER_MODE_SOFT and remove hrtimer_tasklet This patch switches the timer to HRTIMER_MODE_SOFT, which executed the timer callback in softirq context and removes the hrtimer_tasklet.
CVE-2026-2310	7.8	HIGH		0.003		IBM webMethods Integration Server 11.1 IBM webMethods Integration is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-28663	7.8	HIGH		0.001		In buildIntentSenderForUser of LauncherAppsService.java, there is a possible way to launch an activity from the background due to BAL Bypass. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-45520	7.8	HIGH		0.001		In onAttach of BiometricsSettingsBase.java, there is a possible authentication bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-49881	7.8	HIGH		0.001		In serviceClassExists of InCallController.java, there is a possible arbitrary code execution due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-52987	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: avoid double drm_exec_fini() in userq validate When new_addition is true, amdgpu_userq_vm_validate() calls drm_exec_fini(&exec) before iterating over the collected HMM ranges and calling amdgpu_ttm_tt_get_user_pages(). If amdgpu_ttm_tt_get_user_pages() fails in that path, the code jumps to unlock_all and calls drm_exec_fini(&exec) a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68844	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68877	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68892	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69284	7.8	HIGH		0.002		Heap-based buffer overflow in Windows DCOM Server allows an authorized attacker to elevate privileges locally.
CVE-2026-69290	7.8	HIGH		0.002		Stack-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.
CVE-2026-69298	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69323	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69420	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges locally.
CVE-2026-69467	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69580	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69608	7.8	HIGH		0.003		Integer overflow or wraparound in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-72990	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72995	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73001	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73011	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73021	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73026	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-79907	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Double Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79908	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79909	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80161	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Access of Resource Using Incompatible Type ('Type Confusion') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81973	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83498	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to elevate privileges locally.
CVE-2026-83942	7.8	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authorization in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-83952	7.8	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Heap-based buffer overflow in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-83955	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83968	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83969	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83974	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83976	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83979	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19283	7.7	HIGH		0.003		IBM Observability with Instana (Agent) Build 1.0.303 through 1.0.323 IBM Instana Agent Operator could allow an authenticated remote attacker to obtain sensitive information, caused by missing destination namespace validation when copying etcd mTLS client credentials from the openshift-etcd system namespace into an attacker-controlled namespace.
CVE-2026-28802	7.7	HIGH		0.004	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. From version 1.6.5 to before version 1.6.7, previous tests involving passing a malicious JWT containing alg: none and an empty signature was passing the signature verification step without any changes to the application code when a failure was expected.. This issue has been patched in version 1.6.7.
CVE-2026-69192	7.7	HIGH		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.3.1, Address4 accepts an octet written with a leading zero and decodes it as decimal, while the WHATWG URL host parser, inet_aton, and getaddrinfo all decode a leading zero as octal. The library and the network stack therefore disagree about which host a string names. new Address4('012.0.0.1') reports correctFor...
CVE-2026-78623	7.7	HIGH		0.002		The Okta Access Gateway does not sanitize SAML assertion values before interpolating them into database queries in the advanced mode datastore configuration. The unsanitized values are substituted directly into the query string prior to preparation, resulting in unintended SQL execution against the configured backend database.
CVE-2026-81210	7.7	HIGH		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 concatenates three caller-supplied strings into a String.format path on the shared /ds-storage RWX PVC and returns the file with no project ACL — pure IDOR plus traversal. Read is constrained to files named job.log/error.log, but DataStage job logs routinely carry connection strings, {dsnextenc} ciphertxts (decryptable via d2-f023), and customer-data row samples. This i...
CVE-2026-71048	7.6	HIGH		0.003	oracle:product_lifecycle_analytics	Vulnerability in the Oracle Product Lifecycle Analytics product of Oracle Supply Chain (component: Installation Issues). The supported version that is affected is 3.6.1. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Product Lifecycle Analytics. Successful attacks of this vulnerability can result in unauthorized access to critical data or compl...
CVE-2025-48431	7.5	HIGH		0.011	apache:thrift	Mismatched Memory Management Routines vulnerability in Apache Thrift c_glib language bindings. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue. Description: Specially crafted requests can crash an c_glib-based Thrift server with a clean but fatal "free(): invalid pointer" error message.
CVE-2026-17255	7.5	HIGH		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service due to improper validation of the prefix length in ICMPv6 Router Advertisements.
CVE-2026-18175	7.5	HIGH		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to manipulate database transactions due to improper authorization in the DDM target dispatcher.
CVE-2026-24301	7.5	HIGH		0.027	microsoft:copilot	Improper neutralization of special elements used in a command ('command injection') in Microsoft Copilot allows an unauthorized attacker to disclose information over a network.
CVE-2026-25639	7.5	HIGH		0.027	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to versions 0.30.3 and 1.13.5, the mergeConfig function in axios crashes with a TypeError when processing configuration objects containing __proto__ as an own property. An attacker can trigger this by providing a malicious configuration object created via JSON.parse(), causing complete denial of service. This vulnerability is fixed in versions...
CVE-2026-29074	7.5	HIGH		0.006	svgo:svgo	SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 2.1.0 to before version 2.8.1, from version 3.0.0 to before version 3.3.3, and before version 4.0.1, SVGO accepts XML with custom entities, without guards against entity expansion or recursion. This can result in a small XML file (811 bytes) stalling the application and even crashing the Node.js ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-3039	7.5	HIGH		0.01	isc:bind	BIND servers that are configured to use TKEY-based authentication via GSS-API tokens are vulnerable to excessive memory consumption when receiving and processing maliciously-constructed packets. Typically these servers will be found in Active Directory integrated DNS deployments and/or Kerberos-secured DNS environments. This issue affects BIND 9 versions 9.0.0 through 9.16.50, 9.18.0 through 9.18.48, 9.20.0 throu...
CVE-2026-30922	7.5	HIGH		0.008	pyasn1:pyasn1	pyasn1 is a generic ASN.1 library for Python. Prior to 0.6.3, the `pyasn1` library is vulnerable to a Denial of Service (DoS) attack caused by uncontrolled recursion when decoding ASN.1 data with deeply nested structures. An attacker can supply a crafted payload containing thousands of nested `SEQUENCE` (`0x30`) or `SET` (`0x31`) tags with "Indefinite Length" (`0x80`) markers. This forces the decoder to recursivel...
CVE-2026-32286	7.5	HIGH		0.006	jackc:pgproto3	The DataRow.Decode function fails to properly validate field lengths. A malicious or compromised PostgreSQL server can send a DataRow message with a negative field length, causing a slice bounds out of range panic.
CVE-2026-32597	7.5	HIGH		0.003	pyjwt_project:pyjwt	PyJWT is a JSON Web Token implementation in Python. Prior to 2.12.0, PyJWT does not validate the crit (Critical) Header Parameter defined in RFC 7515 §4.1.11. When a JWS token contains a crit array listing extensions that PyJWT does not understand, the library accepts the token instead of rejecting it. This violates the MUST requirement in the RFC. This vulnerability is fixed in 2.12.0.
CVE-2026-33894	7.5	HIGH		0.005	digitalbazaar:forge	Forge (also called `node-forge`) is a native implementation of Transport Layer Security in JavaScript. Prior to version 1.4.0, RSASSA PKCS#1 v1.5 signature verification accepts forged signatures for low public exponent keys (e=3). Attackers can forge signatures by stuffing "garbage" bytes within the ASN structure in order to construct a signature that passes verification, enabling Bleichenbacher style forgery. Thi...
CVE-2026-34986	7.5	HIGH		0.007	go-jose_project:go-jose	Go JOSE provides an implementation of the Javascript Object Signing and Encryption set of standards in Go, including support for JSON Web Encryption (JWE), JSON Web Signature (JWS), and JSON Web Token (JWT) standards. Prior to 4.1.4 and 3.0.5, decrypting a JSON Web Encryption (JWE) object will panic if the alg field indicates a key wrapping algorithm (one ending in KW, with the exception of A128GCMKW, A192GCMKW, a...
CVE-2026-42151	7.5	HIGH		0.004	prometheus:prometheus	Prometheus is an open-source monitoring system and time series database. Prior to versions 3.5.3 and 3.11.3, the client_secret field in the Azure AD remote write OAuth configuration (storage/remote/azuread) was typed as string instead of Secret. Prometheus redacts fields of type Secret when serving the configuration via the /-/config HTTP API endpoint. Because the field was a plain string, the Azure OAuth client s...
CVE-2026-47885	7.5	HIGH		0.003	vmware:spring_framework	The PartEventHttpMessageReader in Spring WebFlux does not enforce the maxPartSize limit when maxInMemorySize is set to -1. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28
CVE-2026-47886	7.5	HIGH		0.003	vmware:spring_framework	Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framew...
CVE-2026-47888	7.5	HIGH		0.003	vmware:spring_framework	A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE
CVE-2026-47889	7.5	HIGH		0.003	vmware:spring_framework	A WebFlux application running on the Jetty 12 Core reactive adapter serializes response cookies without the sameSite attribute. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-48804	7.5	HIGH		0.003		python-socketio is a Python implementation of the Socket.IO realtime client and server. The python-socketio server stores binary `EVENT` and `ACK` messages in memory while it waits to receive their binary attachments. Once all the attachments are received, these messages are then processed. Prior to version 5.16.4, an attacker can submit a binary message and intentionally omit sending one or more of its attachment...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49362	7.5	HIGH		0.006	apache:artemis	An unauthenticated remote attacker can create arbitrary durable queues via the CORE protocol, leading to unauthorized broker state manipulation and potential denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-49363	7.5	HIGH		0.005	apache:artemis	An unauthenticated remote attacker connecting with the CORE protocol can discover cluster node details by sending a SUBSCRIBE_TOPOLOGY request prior to authentication. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-5946	7.5	HIGH		0.019	isc:bind	Multiple flaws have been identified in `named` related to the handling of DNS messages whose CLASS is not Internet (`IN`) — for example, `CHAOS` or `HESIOD`, or DNS messages that specify meta-classes (`ANY` or `NONE`) in the question section. Specially crafted requests reaching the affected code paths — recursion, dynamic updates (`UPDATE`), zone change notifications (`NOTIFY`), or processing of `IN`-specific reco...
CVE-2026-59902	7.5	HIGH		0.004		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, io.netty.handler.codec.sctp.SctpMessageCompletionHandler limits incomplete messages and fragment counts but not maxBufferedBytes, allowing unauthenticated peers to exhaust memory with large SCTP fragments. This issue is fixed in versions 4.1.137.Final and 4.2.17.Final.
CVE-2026-67422	7.5	HIGH		0.007		pymdown-extensions is a collection of extensions for the Python Markdown library. In versions up to and including 11.0, four inline processors (caret, tilde, betterem, and magiclink) use regular expressions whose content groups can partition a run of delimiter characters in exponentially many ways, causing catastrophic backtracking. As a result, a single untrusted Markdown line under 50 bytes rendered with markdown...
CVE-2026-69803	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69929	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69930	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-70065	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70124	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-71092	7.5	HIGH		0.001	oracle:peoplesoft_lease_administrat ion	Vulnerability in the PeopleSoft Enterprise FIN Lease Administration product of Oracle PeopleSoft (component: Lease Administration). The supported version that is affected is 9.2. Difficult to exploit vulnerability allows low privileged attacker with logon to the infrastructure where PeopleSoft Enterprise FIN Lease Administration executes to compromise PeopleSoft Enterprise FIN Lease Administration. While the vu...
CVE-2026-72923	7.5	HIGH		0.012		In Microsoft.OpenApi.YamlReader from 2.0.0-preview.11 until 2.12.0 and from 3.0.0 until 3.10.0, and in Microsoft.OpenApi.Readers prior to 1.6.30, a small YAML OpenAPI document containing nested anchors and aliases can cause uncontrolled resource consumption when parsed through the public YAML reader APIs. YAML is parsed through SharpYaml, which represents aliases as shared nodes in a directed acyclic graph, so the...
CVE-2026-73561	7.5	HIGH		0.005		Hub is a Node.js WebSocket server and client with added features. Prior to 0.2.16, every incoming unauthenticated WebSocket connection triggers loadDefaultConnectionEventListeners to call requestClientId, which calls rpc.send for the get-client-id action and pushes a request into RPC.requests. The RPC.waitForReply function starts a setInterval polling loop every 10 milliseconds that is cleared only after a matchin...
CVE-2026-74761	7.5	HIGH		0.004		Improper input validation in TopicRegion in Apache ActiveMQ, Apache ActiveMQ Broker, and Apache ActiveMQ All on all platforms. An authenticated client can spoof clientId when removing a durable topic subscription. This issue affects Apache ActiveMQ Broker: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ All: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ: before 5.19.11, from 6.0.0 before...
CVE-2026-78523	7.5	HIGH		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-78574	7.5	HIGH		0.001		The Okta Hyperdrive Integration plugin resolves a required assembly using a registry path within the current user's hive without integrity verification. The referenced path is loaded via Assembly.LoadFrom without signature validation, resulting in an unverified assembly executing within the context of the host process or elevated installer.
CVE-2026-80924	7.5	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: krb5 - use kfree_sensitive() for derived key buffers crypto_krb5_prepare_encryption() and crypto_krb5_prepare_checksum() free the buffer holding the freshly derived keys with plain kfree(), leaving the key material behind in the freed slab object.
CVE-2026-81265	7.5	HIGH		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5.
CVE-2026-86093	7.5	HIGH		0.005	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-8862	7.5	HIGH		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 has credentials that are hardcoded in the application source code, allowing unauthorized access to the container registry. The exposed secret enables attackers to pull private container images, potentially revealing proprietary code, configuration details, and other sensitive information.
CVE-2026-9336	7.5	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.
CVE-2026-32589	7.4	HIGH		0.002	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's container image upload process. An authenticated user with push access to any repository on the registry can interfere with image uploads in progress by other users, including those in repositories they do not have access to. This could allow the attacker to read, modify, or cancel another user's in-progress image upload.
CVE-2026-42033	7.4	HIGH		0.008	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, when Object.prototype has been polluted by any co-dependency with keys that axios reads without a hasOwnProperty guard, an attacker can (a) silently intercept and modify every JSON response before the application sees it, or (b) fully hijack the underlying HTTP transport, gaining access to request credentials, headers, an...
CVE-2026-48526	7.4	HIGH		0.004	pyjwt_project:pyjwt	PyJWT is a JSON Web Token implementation in Python. Prior to 2.13.0, when the verifier is decoding JSON Web Tokens, while supporting both asymmetric and HMAC algorithms, the library does not validate use of JSON Web Keys in HMAC algorithm, allowing attacker to use the issuer public key as the secret key for HMAC algorithm. This vulnerability is fixed in 2.13.0.
CVE-2026-81383	7.4	HIGH		0.007	microsoft:visual_studio_code	Use of incorrectly-resolved name or reference in Visual Studio Code allows an unauthorized attacker to disclose information over a network.
CVE-2026-85525	7.4	HIGH		0.001		Improper OCSP response validation in the Snowflake Python, Go, JDBC, and Node.js drivers allowed a revoked TLS certificate to be accepted as valid, because OCSP responses were not reliably bound to the certificate being validated and definitive verification failures were treated as transient. A man-in-the-middle attacker holding a revoked certificate and its private key for a Snowflake or stage hostname could caus...
CVE-2026-87812	7.4	HIGH		0.002		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in Bazaar package cards where the iconURL metadata is inserted directly into HTML img src attributes without escaping. Attackers can inject malicious URLs with event handlers that execute JavaScript in the authenticated SiYuan origin when users view Bazaar listings, enabling API requests and application state manipulation.
CVE-2026-45528	7.3	HIGH		0.001		In getManageSpaceActivityIntent of StorageManagerService.java, there is a possible LaunchAnyWhere chain due to an unsafe PendingIntent. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-47878	7.3	HIGH		0.003	broadcom:spring_batch	DefaultExecutionContextSerializer, used by default in Spring Batch's JDBC job repository, passes Base64-decoded bytes directly to ObjectInputStream.readObject() without an ObjectInputFilter that restricts types to a trusted class allowlist. Spring Batch 6.0.0 - 6.0.4 Spring Batch 5.2.6 and earlier
CVE-2026-69477	7.3	HIGH		0.004	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office Access allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78627	7.3	HIGH		0.001		The Okta Hyperdrive Integration installer does not mask the OAuth client secret when passed as an MSI property. The credential is recorded in plaintext in the installer log, the Application Event Log, and the process command line, all of which are readable by an authenticated local user on the workstation.
CVE-2026-88885	7.3	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the gomod manager when processing unescaped depName parameters in import-path update commands with binarySource=docker mode. Attackers can inject shell metacharacters through malicious dependency names to execute arbitrary commands as the Renovate user during Go module major version updates with postUpdateOptions gomodUpdateImportPaths enabled.
CVE-2026-88888	7.3	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the Mix manager when processing private dependencies with unescaped organization parameters. Attackers can inject shell metacharacters through malicious package names to execute arbitrary commands as the Renovate user in binarySource=docker mode.
CVE-2026-0310	7.2	HIGH		0.003		A buffer overflow vulnerability in the XML processing functionality of Palo Alto Networks PAN-OS® software enables an unauthenticated attacker with network access to the management web or dataplane interface to cause a denial of service (DoS) condition on VM-Series firewalls or execute arbitrary code with root privileges on the PA-Series firewalls. The security risk posed by this issue is minimized when the manag...
CVE-2026-27459	7.2	HIGH		0.007	pyopenssl:pyopenssl	pyOpenSSL is a Python wrapper around the OpenSSL library. Starting in version 22.0.0 and prior to version 26.0.0, if a user provided callback to `set_cookie_generate_callback` returned a cookie value greater than 256 bytes, pyOpenSSL would overflow an OpenSSL provided buffer. Starting in version 26.0.0, cookie values that are too long are now rejected.
CVE-2024-14047	7.1	HIGH		0.001	elastic:winlogbeat	A local vulnerability in the Winlogbeat Windows installer caused runtime files to be placed in a directory writable by unprivileged users. A low-privileged attacker with existing access to the system could pre-position malicious filesystem links, causing a subsequent elevated Winlogbeat operation to write to or delete arbitrary files. Successful exploitation could result in a denial of service.
CVE-2026-69244	7.1	HIGH		0.003		AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Prior to 3.14.3, an out-of-bounds heap read could occur in the C response parser while building an error message for a malformed response. An attacker controlled server, or possibly an accidental response, could trigger a DoS in the client. The vulnerable path was error message construction in aiohttp/_http_parser.pyx, where an llhttp ...
CVE-2026-69305	7.1	HIGH		0.006		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69460	7.1	HIGH		0.005		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69482	7.1	HIGH		0.003		Creation of temporary file in directory with insecure permissions in Windows Error Reporting allows an authorized attacker to perform tampering locally.
CVE-2026-69688	7.1	HIGH		0.006		Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69775	7.1	HIGH		0.005		Use after free in Windows DWM Core Library allows an authorized attacker to elevate privileges over a network.
CVE-2026-74881	7.1	HIGH		0.003	jahlives:openssl_encrypt	openssl_encrypt versions before 1.4.0 configure CORS with allow_origins set to wildcard and allow_credentials enabled to true. Attackers can create malicious websites that make authenticated cross-origin requests to the API on behalf of any user who visits them.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80380	7.1	HIGH		0.001	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote attacker to perform unauthorized actions due to cross-site request forgery.
CVE-2026-82864	7.1	HIGH		0.002		pdfme pdf-lib versions before 5.5.10 contain an unbounded buffer growth vulnerability in the DecodeStream.ensureBuffer() method that allows attackers to cause denial of service by supplying a crafted PDF with a FlateDecode stream containing a decompression bomb. Attackers can upload a small compressed PDF that decompresses to hundreds of megabytes, exhausting memory and crashing the Node.js process or freezing bro...
CVE-2026-85390	7.1	HIGH		0.003		Checkmate through 3.11.0 omits the isAllowed role guard middleware on maintenance-window, notification, and check-deletion routes, allowing read-only users to perform administrative actions. Attackers with user-role sessions can create arbitrary maintenance windows to silence alerts, modify notification channels, and delete monitor check history to erase incident evidence.
CVE-2026-87803	7.1	HIGH		0.002		An authorization bypass vulnerability exists in the Countly Server DBViewer due to flawed sub-pipeline detection in the aggregation stage sanitizer. The /o/db aggregation endpoint parses user-controlled aggregation JSON and passes it through a stage sanitizer that determines whether a nested array is a sub-pipeline by checking if every element contains a key present in a hardcoded KNOWN_STAGE_OPERATORS set. If any...
CVE-2026-88026	7.1	HIGH		0.002		Improper neutralization of regular-expression metacharacters in the LINQ query translation component of the MongoDB C# Driver can cause a caller-supplied character sequence to alter a regular-expression predicate generated by an affected application. An authenticated user who can influence such a value may cause the application to return records beyond those intended by the original filter.
CVE-2026-88027	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the embedded-document relation handling of the MongoDB integration for Laravel can cause a caller-supplied embedded record identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence such an identifier may delete all embedded documents in a targeted record or overwrite an embedded d...
CVE-2026-88028	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the polymorphic relation handling of the MongoDB integration for Laravel can cause a caller-supplied relation identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence a stored relation identifier may cause an affected application to return a document other than the intended relat...
CVE-2026-9176	7.1	HIGH		0.001	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-68897	7.0	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69281	7.0	HIGH		0.003		Use after free in Windows License Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69299	7.0	HIGH		0.002		Use after free in Microsoft COM for Windows allows an authorized attacker to elevate privileges locally.
CVE-2026-69310	7.0	HIGH		0.003		Use after free in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-69430	7.0	HIGH		0.003		Use after free in Windows Embedded Mode Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69470	7.0	HIGH		0.003		Use after free in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-69575	7.0	HIGH		0.003		Use after free in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69645	7.0	HIGH		0.003		Use after free in Windows Message Queuing allows an authorized attacker to elevate privileges locally.
CVE-2026-69694	7.0	HIGH		0.017		Deserialization of untrusted data in Windows IP Address Management (IPAM) Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69791	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69806	7.0	HIGH		0.018		Exposure of sensitive information to an unauthorized actor in .NET allows an authorized attacker to elevate privileges locally.
CVE-2026-72963	7.0	HIGH		0.003		Use after free in Windows Modern Execution Server allows an authorized attacker to elevate privileges locally.
CVE-2026-78464	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-80093	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-81192	7.0	HIGH		0.001		`OpenTelemetry.Resources.Host` NuGet package, which provides OpenTelemetry resource detectors for host, is affected by an untrusted search path vulnerability on macOS. Prior to version 1.16.0-beta.2, the `host.id` resource attribute detector launches the `sh` and `ioreg` executables by bare name rather than by absolute path, so both are resolved through the `PATH` environment variable. A local attacker who is less...
CVE-2026-83940	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2025-15613	6.9	MEDI		0.003		Kyverno before v1.13.4 is vulnerable to server-side request forgery (SSRF) via its Service Call functionality. An attacker with permission to create Kyverno (Cluster)Policies can specify an external URL in a policy's apiCall/service configuration; although Service Call is documented for in-cluster services, it also resolves external addresses, allowing requests to an attacker-controlled server. Because policy cont...
CVE-2026-15417	6.9	MEDI		0.001		In the silabser.sys Windows 8 driver for CP210x devices, a local unprivileged user can use incorrect driver settings to cause a kernel crash.
CVE-2026-21098	6.9	MEDI		0.001		Improper access control in Link to Windows prior to SMR Sep-2026 Release 1 allows local attackers to establish a connection with the PC without proper user interaction.
CVE-2026-39892	6.9	MEDI		0.007	cryptography.io:cryptography	cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. From 45.0.0 to before 46.0.7, if a non-contiguous buffer was passed to APIs which accepted Python buffers (e.g. Hash.update()), this could lead to buffer overflows. This vulnerability is fixed in 46.0.7.
CVE-2026-42039	6.9	MEDI		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, toFormData recursively walks nested objects with no depth limit, so a deeply nested value passed as request data crashes the Node.js process with a RangeError. This vulnerability is fixed in 1.15.1 and 0.31.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69198	6.9	MEDI		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. From 10.1.1 until 10.2.2, every special-use classification method is built on isInSubnet, which short-circuits to false whenever the address's own subnet mask is shorter than the reference range's mask. That mask comes verbatim from the CIDR suffix on the parsed input, so appending a suffix such as /0 suppresses classificat...
CVE-2026-69248	6.9	MEDI		0.002		cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. In versions 45.0.0 through 48.0.0, if an intermediate constrained CA permits the DNS name foo.example.com, and the leaf certificate has a wildcard in its DNS SAN of *.example.com, python-cryptography's verifier accepts which allows escaping outside of the permitted names. The core issue is in DNSConstraint::matc...
CVE-2026-74871	6.9	MEDI		0.001	jahllives:openssl_encrypt	openssl_encrypt versions before 1.4.6 contain a key derivation flaw in sequential XOR composition mode where the last stage cancels out during key generation. When configured with a single KDF and no prior hashing stage, attackers can bypass memory-hard key derivation and perform offline password cracking at SHA-256 speed instead of the configured KDF cost.
CVE-2026-84697	6.9	MEDI		0.002		Mailpit's IsInternalIP deny list function fails to block the Azure WireServer address 168.63.129.16 and the RFC 2765/6145 IPv4-translated IPv6 prefix, allowing server-side request forgery to internal destinations. Attackers can supply hostnames resolving to these addresses in message content to reach the link check API and proxy endpoint for accessing internal resources.
CVE-2026-84968	6.9	MEDI		0.002	mongodb:php_driver	An out-of-bounds read in the BSON decoding component of the MongoDB PHP driver may allow an unauthenticated party who supplies specially formed input to have a small amount of adjacent process memory copied into an error message that is returned to application code. This may result in unintended disclosure of limited memory contents.
CVE-2026-88884	6.9	MEDI		0.002		Renovate is a dependency update automation tool. In versions before 44.3.1 (and Mend Renovate CE/EE images before 15.4.0, mend-renovate-ce Helm chart before 15.4.0, mend-renovate-enterprise-edition Helm chart before 10.4.0), digest updates are not subject to the internal `minimumReleaseAge` (stability age) checks. When a repository configures `minimumReleaseAge` and has dependencies with `updateType=digest` — for ...
CVE-2026-72999	6.8	MEDI		0.003		Out-of-bounds read in Windows USB Hub Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-78579	6.8	MEDI		0.002		The Okta Access Gateway does not sanitize SAML assertion attribute values before interpolating them into LDAP search filters in the LDAP datastore configuration. The raw values are substituted directly into the filter string and passed to the LDAP search operation, resulting in modification of the intended query logic.
CVE-2026-78625	6.7	MEDI		0.002		The Okta Access Gateway does not sanitize dashboard label values before writing them into generated PHP configuration files. The generated file is automatically included during authentication requests, resulting in execution with the privileges of the web server process.
CVE-2026-78630	6.7	MEDI		0.002		The Okta Access Gateway does not neutralize shell metacharacters in SNMP configuration values before a privileged script uses them to construct OS commands. An authenticated local user with access to the management interface can supply crafted values, resulting in the execution of arbitrary OS commands with root privileges.
CVE-2026-85981	6.7	MEDI		0.001		The administrative panel of the Auth0 AD/LDAP Connector (versions 6.5.0 and earlier) listens on the local loopback interface without requiring authentication. This allows a local, low-privileged user or process on the host system to access the panel's management endpoints without credentials. Through these endpoints, a local user can read configuration details, including plaintext Active Directory service account ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19201	6.6	MEDI		0.003		An uncontrolled recursion vulnerability in the Windows SIPA event log parser of Google go-attestation versions up to and including 0.6.1 allows an attacker to cause a denial of service (DoS). The (*WinEvents).readELAMAggregation function recurses for every nested elamAggregation sub-event without enforcing a maximum recursion depth limit, while the size guard is bypassed on recursive execution paths. By submitting...
CVE-2026-78545	6.6	MEDI		0.004		The Okta Access Gateway does not sanitize the application label field before including it in the generated nginx configuration file. The unsanitized value is interpolated into an nginx server block directive, resulting in execution of injected directives.
CVE-2026-78550	6.6	MEDI		0.004		The Okta Access Gateway management console passes user-supplied input to eval() without sanitization during an authenticated administrator SSH session. As a result, the unsanitized input is executed directly, leading to code execution with the privileges of the management console.
CVE-2026-14470	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow an authenticated attacker to traverse directories on the system. An attacker could send a specially crafted URL request containing "dot dot" sequences (./.) to view arbitrary files on the system.
CVE-2026-17273	6.5	MEDI		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a NULL pointer dereference.
CVE-2026-17444	6.5	MEDI		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection.
CVE-2026-18076	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a memory leak.
CVE-2026-19645	6.5	MEDI		0.003		IBM MQ Agent CD: v1.0.0, v1.0.1, v2.0.0, v2.0.1 An authenticated user with a valid session cookie can submit arbitrarily large or computationally expensive requests that cause the LLM agent workers to be held for extended periods — ranging from tens of seconds to over ten minutes per request. When multiple such requests are sent concurrently, the agent worker pool becomes exhausted, causing all other IBM MQ Console u...
CVE-2026-2377	6.5	MEDI		0.004	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay and mirror registry for Red Hat OpenShift. The log export feature in these products allows an authenticated user to specify an arbitrary callback URL. A backend process then makes server-side HTTP requests to this provided URL. This vulnerability, known as Server-Side Request Forgery (SSRF), could allow an attacker to send requests from the application's internal network, potential...
CVE-2026-42041	6.5	MEDI		0.006	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, the Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution to silently suppress all HTTP error responses (401, 403, 500, etc.), causing them to be treated as successful responses. This completely bypasses application-level authentication and error handling. The root...
CVE-2026-56818	6.5	MEDI		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, the RedisArrayAggregator Redis codec clears retained partial aggregate state when the maxNestedArrayDepth limit is exceeded, but it does not clear the same state when the sibling maxElements limit is exceeded. A peer can start a valid RESP array, send a bulk string child, then send a nested array header l...
CVE-2026-57822	6.5	MEDI		0.005	apache:artemis	When the broker is processing message-based management requests, sent by an authenticated messaging client that is authorized with MANAGE permission to perform management-via-messaging, the parameter processing can trigger Java deserialization of certain method parameters that the broker will not utilise. The permitted types allow to craft a payload causing excessive computation and pinning the processing thread, ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-59903	6.5	MEDI		0.002		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, io.netty.handler.codec.http.cors.CorsHandler setVaryHeader replaces application Vary headers such as Authorization or Cookie with Origin, allowing a caching proxy or CDN to reuse authenticated responses across users and disclose sensitive information. This issue is fixed in versions 4.1.137.Final and 4.2....
CVE-2026-69624	6.5	MEDI		0.007		Incomplete list of disallowed inputs in Active Directory Certificate Services (AD CS) allows an authorized attacker to perform tampering over a network.
CVE-2026-69781	6.5	MEDI		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Missing release of memory after effective lifetime in Windows DHCP Client allows an unauthorized attacker to deny service over an adjacent network.
CVE-2026-72956	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Untrusted pointer dereference in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-75880	6.5	MEDI		0.004	apache:artemis	An authenticated client could attach a consumer with a selector containing crafted wildcard usage that results in excessive evaluation during message delivery attempts, occupying a shared broker thread and leading to denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes...
CVE-2026-78658	6.5	MEDI		0.003		IBM UCD - IBM UrbanCode Deploy 7.2 through 7.2.3.25, and 7.3 through 7.3.2.20 and IBM UCD - IBM DevOps Deploy 8.0 through 8.0.1.15, 8.1 through 8.1.2.8, and 8.2 through 8.2.2.1 IBM DevOps Deploy / IBM UrbanCode Deploy (UCD) is susceptible to an formation disclosure vulnerability when processing redacted property values. If a deployment is configured with a secure property that starts with certain non-ASCII charact...
CVE-2026-79725	6.5	MEDI		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to read arbitrary files due to improper access control.
CVE-2026-80082	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80084	6.5	MEDI		0.007	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80086	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80087	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80089	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80091	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Use of uninitialized resource in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80378	6.5	MEDI		0.003	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to improper authorization.
CVE-2026-81554	6.5	MEDI		0.005	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-82092	6.5	MEDI		0.005	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-82100	6.5	MEDI		0.004	ibm:datastage_on_cloud_pak_for_d ata	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to a path traversal vulnerability.
CVE-2026-86597	6.5	MEDI		0.001		Insertion of sensitive information into log files in the Snowflake Python, Go, JDBC, Node.js, PHP PDO, and ODBC drivers allowed authentication tokens, query-result encryption keys, pre-signed cloud-storage URLs, and SAML assertions to be written to diagnostic logs in circumstances where the available log redaction did not cover all affected log paths and data types. An attacker with read access to the log destinat...
CVE-2026-9138	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 Langflow could allow an authenticated attacker to write arbitrary files to the server due to improper input validation in the SaveToFileComponent. The application constructs local file paths using attacker-controlled input without sufficient sanitization when handling requests to the /api/v1/run/{flow_id} endpoint. An attacker with low-privileged authenticated access (such as ...
CVE-2026-9225	6.5	MEDI		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an authenticated attacker to access sensitive files belonging to other users due to improper access control in the File/Read File component. When executing flows through the /api/v1/run/advanced/{flow_id} endpoint, the application allows component inputs to reference storage paths using arbitrary user or flow identifiers without verifying ownership. An att...
CVE-2026-9745	6.5	MEDI		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 has operations that are performed without validating bucket ownership using the ExpectedBucketOwner parameter. This omission may allow a remote attacker to exploit misconfigurations or naming collisions to redirect application requests to an unintended S3 bucket under their control.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69878	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2025-62718	6.3	MEDI		0.012	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.0 and 0.31.0, Axios does not correctly handle hostname normalization when checking NO_PROXY rules. Requests to loopback addresses like localhost. (with a trailing dot) or [::1] (IPv6 literal) skip NO_PROXY matching and go through the configured proxy. This goes against what developers expect and lets attackers force requests through a ...
CVE-2026-63335	6.3	MEDI		0.004		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.31.0, inbound AMQP command assembly in src/main/java/com/rabbitmq/client/impl/CommandAssembler.java processes a content-bearing method and header whose remainingBodyBytes value is smaller than a following AMQP.FRAME_BODY payload. CommandAssembler.consumeBodyFrame subtracts the peer-con...
CVE-2026-69243	6.3	MEDI		0.004		AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Prior to 3.14.2, the HTTP parsers were vulnerable to a request smuggling attack relating to WebSocket upgrades. If using the server-side component, an attacker may be able to execute a request smuggling vulnerability using an edge case in the WebSocket upgrade procedure. A WebSocket upgrade request with a body could cause the parser to...
CVE-2026-81994	6.3	MEDI		0.003	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') vulnerability that could lead to arbitrary file system read. An attacker could exploit this vulnerability to access sensitive files and directories outside the intended access scope. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is chan...
CVE-2026-81997	6.3	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.
CVE-2026-84969	6.3	MEDI		0.002	mongodb:c_driver	A memory-handling error in the BSON-to-JSON conversion helpers of the MongoDB C Driver can write a small number of bytes past the end of a heap buffer when a binary field is encoded and the output is cut short at a caller-configured length limit. A party who supplies the document content, with no privileges on the application that links the driver, may cause a small amount of data outside the intended buffer to be...
CVE-2026-85167	6.3	MEDI		0.002	n8n:n8n	n8n before 2.35.4 and 2.36.x before 2.36.2 contain a query injection vulnerability in the Elasticsearch Document Get All and Google Cloud Firestore Document Query operations, which build their JSON query by interpolating expression values directly into the query string before parsing. A value containing quote and brace characters can close the intended field and introduce new query operators, turning an intended s...
CVE-2026-88859	6.3	MEDI		0.003		A flaw was found in Evolution. A remote attacker can exploit this vulnerability by sending a specially crafted HTML email containing a spoofed vCard control. When a victim clicks on this control, Evolution's trusted JavaScript handler incorrectly assigns an attacker-controlled JavaScript URL to an iframe's source. This action leads to arbitrary JavaScript execution within the mail-viewing context, effectively bypa...
CVE-2026-68499	6.2	MEDI		0.002		re2 provides Node.js bindings for Google's RE2 regular expression engine. Prior to 1.25.2, re2's String.prototype.match implementation with a global RE2 pattern that can match the empty string fails to advance its native matching cursor in lib/match.cc, causing an infinite loop and unbounded native memory growth that blocks the event loop and can exhaust host memory. This issue is fixed in 1.25.2.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71430	6.2	MEDI		0.002		node-re2 provides RE2 regular expression bindings for Node.js. Prior to version 1.25.1, the WrappedRE2::Replace function built its replacement result and passed it to V8 using ToLocalChecked without checking for the empty MaybeLocal that V8 returns when the resulting string or buffer exceeds V8's maximum string length. When a global replace uses an output amplifying replacement template, the result can grow quadra...
CVE-2026-22029	6.1	MEDI		0.009	shopify:react-router, shopify:remix-run/vreact	React Router is a router for React. In @remix-run/router version prior to 1.23.2 and react-router 7.0.0 through 7.11.0, React Router (and Remix v1/v2) SPA open navigation redirects originating from loaders or actions in Framework Mode, Data Mode, or the unstable RSC modes can result in unsafe URLs causing unintended javascript execution on the client. This is only an issue if you are creating redirect paths from u...
CVE-2026-47883	6.1	MEDI		0.002	vmware:spring_framework	UrlHandlerFilter can be vulnerable to an open redirect when configured with very broadly matching patterns. The issue applies to the filter variants in both Spring MVC and Spring WebFlux. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-47887	6.1	MEDI		0.002	vmware:spring_framework	A Spring MVC application that uses UriFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-61526	6.1	MEDI		0.002		AdonisJS HTTP Server is a package for handling HTTP requests in the AdonisJS framework. In versions 8.0.0-next.0 through 8.2.0 and 9.0.0 through 9.0.2, the error.message is interpolated into the default HTML exception response without escaping, allowing a crafted missing-route URL to execute attacker-controlled JavaScript when a victim opens it and no custom status page or JSON response handles the error. When de...
CVE-2026-71478	6.1	MEDI		0.002		league/commonmark is a PHP library for parsing and rendering CommonMark Markdown. From 1.5.0 until 2.9.0, the AttributesExtension's href and src unsafe-link filter can be bypassed by embedding control bytes, such as a tab, carriage return, line feed, or leading C0 control character, in a javascript: URL that browsers discard before parsing the scheme, causing the browser to still execute the script even when the u...
CVE-2026-85227	6.1	MEDI		0.002	misp-project:misp	MISP contains a reflected Cross-Site Scripting (XSS) vulnerability in the event attribute filtering query builder. The taggedAttributes and galaxyAttachedAttributes URL parameters were inserted into the query-builder rules without HTML escaping before being serialized as JSON and embedded inside a <script> element. Because JsonTool::encode() uses JSON_UNESCAPED_SLASHES, an attacker-controlled value containing a ...
CVE-2026-85484	6.1	MEDI		0.003		HTML::FormHandler versions before 0.410002 for Perl render option group labels and radio button labels into HTML without escaping. The Select, RadioGroup, CheckboxGroup and HorizCheckboxGroup widgets render a group label unescaped, Select into a label attribute and the other three into element content. RadioGroup also renders each radio button's own label unescaped. Any application whose option list is built fro...
CVE-2026-85485	6.1	MEDI		0.002		HTML::FormHandler versions before 0.410002 for Perl render some error messages into HTML without escaping. The Table form layout and the Bootstrap 2 and 3 wrappers splice each error string straight into the surrounding markup. Version 0.410000, the fix for CVE-2026-19872, escaped the equivalent values in the other layouts and wrappers, and 0.410002 extended that to these three. Error messages that contain attack...
CVE-2026-85630	6.1	MEDI		0.003		HTML::FormHandler versions before 0.410002 for Perl render field attributes into HTML without escaping using the process_attrs method. Any application with fields or field labels where some attributes are built from data rather than literals allows attacker-influenced text in an attribute value that can override the field attributes or embed JavaScript in rendered pages. For example, the RadioGroup widget uses t...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88023	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB PHP Library can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88024	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Rust Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88025	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C# Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file c...
CVE-2026-88029	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Python Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS fi...
CVE-2026-88030	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Ruby Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88031	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Go Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may cause all GridFS file chunks in the affected bucket to be removed, rendering sto...
CVE-2026-88033	6.1	MEDI		0.003	mongodb:java_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Java Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88034	6.1	MEDI		0.003	mongodb:c\+\+_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C++ Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ...
CVE-2026-88036	6.1	MEDI		0.003	mongodb:c_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ch...
CVE-2026-78552	6.0	MEDI		0.003		The Okta Access Gateway does not apply its Lua directive restriction to the application-level custom configuration field. The field is interpolated directly into the nginx server block without inspection, resulting in execution of injected directives.
CVE-2026-78622	6.0	MEDI		0.001		The Okta Verify for Windows uninstaller does not verify whether the user data directory is a filesystem junction before deleting its contents with elevated privileges. The delete operation follows the junction target, resulting in recursive deletion of unintended directory contents.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79780	6.0	MEDI		0.001		rc1one before v1.75.0 fails to sanitize IBM IAM bearer tokens and SSE-C encryption keys during S3 redirect callbacks, allowing credentials to be preserved across scheme or host changes. Attackers observing network traffic from a trusted endpoint can capture reusable IBM IAM tokens on same-host HTTPS-to-HTTP downgrades or SSE-C keys on cross-origin redirects to access protected S3 objects.
CVE-2026-0307	5.9	MEDI		0.001		Multiple local privilege escalation vulnerabilities in the Palo Alto Networks GlobalProtect™ app allows a local user to escalate their privileges to NT AUTHORITY\SYSTEM on Windows and root on macOS and Linux. This enables a non-administrative user to execute arbitrary commands with administrative privileges. This GlobalProtect app on iOS, Android and ChromeOS is not impacted.
CVE-2026-78620	5.9	MEDI		0.003		The Okta Access Gateway Kerberos configuration handler does not validate file paths specified in event payloads before writing file contents. The path from the event payload is used directly as the write destination, resulting in files being written to unintended locations on the appliance filesystem.
CVE-2026-84970	5.9	MEDI		0.001	mongodb:c\ +_driver	A numeric truncation weakness exists in the JSON parsing component of the MongoDB C++ Driver's BSON library. An actor who controls the text that an embedding application hands to the library's public JSON parsing interface, when that text is very large, can cause the library to read memory beyond the supplied buffer and return it to the caller, to silently accept only part of the input as a complete document, or t...
CVE-2026-88763	5.9	MEDI		0.003		A flaw was found in the skupper-router component of Red Hat Service Interconnect, which is used to provide secure communication between distributed services. The issue occurs when the router processes a specially crafted network message using its AMQP field parser. Due to a lack of bounds on recursion during parsing, the router can run out of stack memory and crash, leading to a denial of service for the interconn...
CVE-2026-9036	5.9	MEDI		0.001	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 does not validate or improperly validates TLS certificate validation, which could allow an attacker to obtain sensitive information using man in the middle techniques.
CVE-2026-9744	5.9	MEDI		0.001	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 does not validate or improperly validates TLS certificate validation, which could allow an attacker to obtain sensitive information using man in the middle techniques.
CVE-2026-0306	5.8	MEDI		0.001		A vulnerability in the EndPoint Data Loss Prevention (DLP) enforcement of Palo Alto Networks Prisma® Access Agent enables a local user to bypass configured DLP policy enforcement controls and exfiltrate sensitive data. This Prisma Access Agent on macOS, Linux, iOS, Android and Chrome OS is not affected.
CVE-2026-67550	5.7	MEDI		0.002		re2 provides Node.js bindings for Google's RE2 regular expression engine. Prior to 1.25.2, re2 validates lastIndex against the UTF-8 byte length of a subject but uses it as a UTF-16 code-unit offset in exec, test, match, replace, and split, allowing an attacker-influenced lastIndex on a non-ASCII subject to trigger an out-of-bounds heap read and an uncatchable process crash, with limited heap information disclosur...
CVE-2026-88035	5.7	MEDI		0.001	mongodb:c_driver	A size check in the client-side authentication path of the MongoDB C Driver can wrap around, so an unusually large user-name value is accepted and copied past the end of a small buffer. A party able to set the driver's connection settings may cause the application that embeds the driver to terminate unexpectedly. Reaching this code requires a build in which the optional external SASL authentication backend is pres...
CVE-2026-78629	5.6	MEDI		0.001		The Okta Hyperdrive agent plugin returns a success response without a signed SAML assertion when the organization's policy requires no MFA for a given user. The response contains only a bare boolean validation indicator with no cryptographic artifact, resulting in an unverifiable authentication verdict being delivered to the relying application.
CVE-2026-17270	5.5	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to cause a denial of service due to a stack-based buffer overflow.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-17442	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to credentials being written to trace logs in cleartext.
CVE-2026-18622	5.5	MEDI		0.001	apple:macos, foxit:pdf_editor, foxit:pdf_reader, microsoft:windows	Foxit PDF Editor/Reader inconsistently alerts users when signature fields are abnormally modified, including alterations to appearance, coordinates, or field duplication. This may mislead users into trusting tampered documents, since the UI cannot accurately reflect the actual integrity status of signatures.
CVE-2026-24049	5.5	MEDI		0.003	wheel_project:wheel	wheel is a command line tool for manipulating Python wheel files, as defined in PEP 427. In versions 0.40.0 through 0.46.1, the unpack function is vulnerable to file permission modification through mishandling of file permissions after extraction. The logic blindly trusts the filename from the archive header for the chmod operation, even though the extraction process itself might have sanitized the path. Attackers...
CVE-2026-32591	5.5	MEDI		0.003	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's Proxy Cache configuration feature. When an organization administrator configures an upstream registry for proxy caching, Quay makes a network connection to the specified registry hostname without verifying that it points to a legitimate external service. An attacker with organization administrator privileges could supply a crafted hostname to force the Quay server to make request...
CVE-2026-69674	5.5	MEDI		0.003		Missing authentication for critical function in Windows Modern Device Management (MDM) allows an authorized attacker to bypass a security feature locally.
CVE-2026-72966	5.5	MEDI		0.003		Missing authorization in Windows Remote Access Connection Manager allows an authorized attacker to perform tampering locally.
CVE-2026-73004	5.5	MEDI		0.002		Missing authentication for critical function in Windows Autopilot allows an authorized attacker to perform tampering locally.
CVE-2026-73008	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of private personal information to an unauthorized actor in Windows Biometric Service allows an authorized attacker to disclose information locally.
CVE-2026-79910	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80160	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80162	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81978	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81984	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81991	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81993	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Heap-based Buffer Overflow vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83501	5.5	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to disclose information locally.
CVE-2026-86213	5.5	MEDI		0.003		A vulnerability was found in Mstfakts College-Management-System. This issue affects the function mysqli_query of the file Front-end/university.php of the component Search Handler. The manipulation of the argument book_name/book_author results in sql injection. The attack may be performed from remote. The exploit has been made public and could be used. This product utilizes a rolling release system for continuous d...
CVE-2026-88055	5.5	MEDI		0.002		AnythingLLM is an application that turns pieces of content into context that any LLM can use as references during chatting. In 1.16.1 and earlier, the manager role can store meta_page_title or meta_page_favicon through /api/admin/system-preferences, and MetaGenerator inserts those values into production homepage HTML without escaping attribute values or text content. The values pass unchanged through server/models...
CVE-2022-26962	5.4	MEDI		0.002		Italtel NFV 11.1.2-20210318 allows Multiple Stored XSS under NP_BCCAS-RMCTRL-01/IMCSCIWebGui/configuration.jsp?opracion=list&object=announcementAS via the name, username, or mrfAnnouncementNameparameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the page containing it.
CVE-2026-17621	5.4	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote attacker to traverse directories on the system. An attacker could send a specially crafted URL request containing "dot dot " sequences (/.. /) to view arbitrary files on the system.
CVE-2026-36392	5.4	MEDI		0.002		FairSketch Rise CRM Version 3.9.6 is vulnerable to Cross Site Scripting (XSS). An authenticated administrator can inject arbitrary JavaScript into an item's title, which is stored server-side and executed in the browser of any client user who visits the store page, enabling session hijacking, account takeover, and phishing.
CVE-2026-47880	5.4	MEDI		0.002	vmware:spring_integration	A producer who can publish to a JMS destination consumed by any Spring Integration JMS inbound component can set String JMS properties named replyChannel, errorChannel, or json__TypeId__ which are copied verbatim into the Spring Integration MessageHeaders. Spring Integration 7.1.0 Spring Integration 7.0.0 - 7.0.5 Spring Integration 6.5.0 - 6.5.10 Spring Integration 6.4.0 - 6.4.12 Spring Integration 5.5.21 and earlier
CVE-2026-69402	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-71803	5.4	MEDI		0.002		money-pos 1.0 contains a stored Cross-Site Scripting (XSS) vulnerability. When processing returns, the backend fails to filter or escape the goodsName parameter, directly concatenating it into the order log description; the frontend subsequently renders this content using v-html. An attacker with product creation privileges can inject a malicious JavaScript payload, causing unauthorized code execution when an admini...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75669	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75671	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75672	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75675	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75678	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75679	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75680	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75681	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75685	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75687	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75690	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75691	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75693	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75694	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75695	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75696	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75701	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75702	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75704	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75705	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75707	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75708	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75710	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75712	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75713	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75714	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75715	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75717	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75718	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75719	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75720	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75724	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75725	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75727	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75730	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75731	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75734	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75736	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75737	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75739	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75741	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75742	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-79905	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-84385	5.4	MEDI		0.001		A improper access control vulnerability in Fortinet FortiSOAR PaaS 7.6.0 through 7.6.6, FortiSOAR PaaS 7.5.0 through 7.5.3, FortiSOAR PaaS 7.4 all versions, FortiSOAR PaaS 7.3 all versions, FortiSOAR on-premise 7.6.0 through 7.6.6, FortiSOAR on-premise 7.5.0 through 7.5.3, FortiSOAR on-premise 7.4 all versions, FortiSOAR on-premise 7.3 all versions may allow attacker to escalation of privilege via <insert attack v...
CVE-2026-16660	5.3	MEDI		0.004	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a remote attacker to cause a denial of service due to an out-of-bounds read.
CVE-2026-45292	5.3	MEDI		0.011		opentelemetry-java is the Java implementation of the OpenTelemetry API for recording telemetry, and SDK for managing telemetry recorded by the API. Prior to 1.62.0, a vulnerability affects the baggage propagation implementation in opentelemetry-api and opentelemetry-extension-trace-propagators. Parsing oversized baggage causes unbounded memory allocation and CPU consumption. Because baggage is automatically re-inj...
CVE-2026-48094	5.3	MEDI		0.004		The ShareOpenly WordPress plugin prior to version 1.2.1 contains a Cross-Site Scripting vulnerability caused by the absence of WordPress's `esc_url()` escaping function on the `\$url` variable before it is rendered into HTML content. This variable is constructed from `home_url( add_query_arg( array(), \$wp->request ) )` and is concatenated directly into an HTML `href` attribute on every singular post or page where t...
CVE-2026-54048	5.3	MEDI		0.006	apache:impala	Specifying tblproperties('avro.schema.url'=' http://...') or with a 'file:/// ' URI on a table in Impala 2.0.0 to 4.5.1 on all platforms allows an attacker to trigger a GET request to internal endpoints they may not have access to but that Impala does and the response my be exposed via parsing error messages. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-61632	5.3	MEDI		0.004		PyMdown Extensions is a set of extensions for the Python-Markdown markdown project. In versions up to and including 10.21.3, the b64 extension is vulnerable to a path traversal that discloses arbitrary files: it inlines images referenced by by joining the src onto the configured base_path with os.path.normpath and opening the result directly, without verifying that the resolved path stays inside ba...
CVE-2026-73565	5.3	MEDI		0.004		@hono/node-server allows running the Hono application on Node.js. From 2.0.0 until 2.0.10, a WebSocket upgrade request to an upgradeWebSocket route with a missing or malformed Sec-WebSocket-Key header causes src/websocket.ts to retain the request's IncomingMessage in waiterMap and leave waitForWebSocket pending because ws.handleUpgrade emits no connection event. The aborted handshake therefore has no cleanup path,...
CVE-2026-78631	5.3	MEDI		0.001		The Okta Hyperdrive Agent writes the decoded SAML bearer assertion to a local application log file at the default log level on every successful MFA completion. This insertion of sensitive information into the log file makes a live authentication credential readable by any local user with access to the log file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82867	5.3	MEDI		0.002		@pdfme/schemas before 5.5.9 contains a cross-site scripting vulnerability in the Select schema plugin that fails to sanitize option values before interpolating them into HTML via innerHTML. Attackers can supply malicious templates with crafted option values containing HTML and JavaScript to execute arbitrary code in users' browsers.
CVE-2026-82868	5.3	MEDI		0.002		@pdfme/schemas before 5.5.9 contains a cross-site scripting vulnerability in the SVG schema plugin that renders user-supplied SVG content directly to innerHTML without sanitization. Attackers can inject malicious SVG with embedded scripts, event handlers, or foreignObject elements to execute arbitrary JavaScript in users' browsers when viewing or filling templates.
CVE-2026-85230	5.3	MEDI		0.002	misp-project:misp	A persistent unsafe URL injection vulnerability exists in the MISP dashboard ButtonWidget configuration. Dashboard widget URLs were validated only when the widget was rendered and were not validated when the configuration was saved. As a result, an authenticated user able to modify dashboard widget settings could persist arbitrary URL values, including URLs using the javascript: scheme, through either of the dashb...
CVE-2026-88011	5.3	MEDI		0.002	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. Prior to 2.11.56, and from 3.0.0 until 3.7.12, a client-supplied dot-form header such as X.Authenticated.User survives ForwardAuth replacement and underscoreHeadersStrategy because Go treats it as distinct from X-Authenticated-User while normalization-prone CGI, WSGI, PHP, and NGINX backends collapse both names. A backend can consequently consume the ...
CVE-2026-88046	5.3	MEDI		0.003		rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone core does not reject parent-directory segments in source Object.Remote() values before fs/list, fs/walk, fs/sync, and fs/operations pass those values to destination backends. A flat-keyspace source object store populated with native non-rclone tooling can contain a raw .. key segmen...
CVE-2026-88057	5.3	MEDI		0.004		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.0, Angular's compiler and runtime in @angular/core and @angular/compiler could omit or select an incorrect sanitizer for security-sensitive directive host bindings because SecurityContext was derived from the declaring directive or component selecto...
CVE-2026-88879	5.3	MEDI		0.002	traefik:traefik	Traefik is an HTTP reverse proxy and load balancer. In Traefik v1.x, v2.x through v2.11.55, and v3.0.0 through v3.7.11, header names are canonicalized only on dashes, so X-Auth-User, X_Auth_User and X.Auth.User are treated as three distinct headers by Traefik, while backends that derive variable names from header names (CGI, WSGI, PHP, NGINX and others) collapse them into a single variable. A client can therefore ...
CVE-2026-88892	5.3	MEDI		0.003		OpenPanel is an analytics platform. In all versions (no patched release available at time of publication), the data importer fetches a caller-supplied URL with plain fetch instead of the project's existing SSRF guard (apps/api/src/utis/safe-fetch.ts). In packages/importer/src/providers/umami.ts, parseRemoteFile calls fetch() on config.fileUrl, which is validated only by z.string().url(), so values such as http://...
CVE-2026-9338	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted request. A remote attacker could exploit this vulnerability to trigger excessive resource consumption, potentially leading to reduced availability of the affected service.
CVE-2026-9667	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2026-0297	5.2	MEDI		0.003	paloaltonetworks:globalprotect	A buffer overflow vulnerability exists in the Palo Alto Networks GlobalProtect™ app that enables a man-in-the-middle (MitM) attacker or a rogue gateway to disrupt system processes and potentially execute arbitrary code with elevated privileges (SYSTEM privileges on Windows, and root privileges on macOS and Linux).

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-0298	5.2	MEDI		0.003	paloaltonetworks:globalprotect	An improper input validation vulnerability exists in the Windows Pre-Logon Access Provider (PLAP) component of the Palo Alto Networks GlobalProtect™ app on Windows devices which enables a man-in-the-middle (MitM) attacker to execute arbitrary code with SYSTEM privileges on an affected client. The GlobalProtect app on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2026-63336	5.1	MEDI		0.002		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.0, com.rabbitmq.client.ConnectionFactory.useSslProtocol() and ConnectionFactory.useSslProtocol(String) configure com.rabbitmq.client.TrustEverythingTrustManager and leave hostname verification disabled, causing arbitrary server certificates, including self-signed certificates, to be...
CVE-2026-71498	5.1	MEDI		0.002		node-re2 provides RE2 regular expression bindings for Node.js. Prior to version 1.26.1, passing a Buffer whose final bytes form a truncated (incomplete) multi-byte UTF-8 sequence could cause the native binding to read past the end of the allocated buffer while attempting to decode the final, incomplete code point. This could result in an out-of-bounds read and potential disclosure of adjacent memory contents. This...
CVE-2026-85601	5.1	MEDI		0.002		Grav Admin before 2.0.20 fails to sanitize output from marked.parse() before injecting it into the DOM via Svelte's {@html} directive in MarkdownEditor and MarkdownModal components. Attackers can inject javascript: URI schemes in plugin or theme changelogs to execute arbitrary code in authenticated admin sessions without requiring site access.
CVE-2026-87912	5.1	MEDI		0.002		A missing S3 bucket ownership verification in the AWS Security Agent plugin in Amazon aws-agents-for-devsecops before 1.1.0 might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account identifier. To remediate this issue, u...
CVE-2026-87913	5.1	MEDI		0.002		A missing S3 bucket ownership verification in the AWS Security Agent MCP server before 0.2.0 version might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account identifier. To remediate this issue, users should upgrade to ...
CVE-2026-78635	5.0	MEDI		0.002		The Okta Privileged Access client URL handler does not insert an option terminator before appending the target value to the command-line arguments. When a scaleft:// protocol handler link contains a value beginning with a hyphen, the underlying CLI framework interprets it as a command-line flag, causing unintended modification of the SSH client's behavior.
CVE-2026-79723	5.0	MEDI		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of user-controlled API endpoints.
CVE-2026-80434	5.0	MEDI		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to manipulate runtime caches and cause a denial of service due to an insecure direct object reference.
CVE-2026-78624	4.9	MEDI		0.004		The Okta Access Gateway backup restore function does not validate the filename embedded in an encrypted backup payload. This results in writing file contents to unintended locations on the appliance filesystem.
CVE-2026-0304	4.8	MEDI		0.002		A privilege escalation vulnerability in Palo Alto Networks Cortex XDR Broker VM enables an authenticated low privileged user with man-in-the-middle (MitM) access to execute code with root privileges on the Broker VM.
CVE-2026-67617	4.8	MEDI		0.002		Microweber CMS through 2.0.20 contains a stored cross-site scripting vulnerability in the content tagging system that allows admin-authenticated attackers to inject arbitrary JavaScript by submitting malicious payloads via the tag_names parameter of the GET /api/save_content_admin endpoint, bypassing three independent sanitization controls including XSS middleware that ignores GET requests, a strip_unsafe() functi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69615	4.8	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-71852	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, a crafted PDF can cause long runtimes and large memory consumption when pypdf/_font.py function Font._collect_cid_character_widths expands unusually large CID font /W width ranges or excessive width entries during text extraction. This issue is fixed in 6.15.0.
CVE-2026-78560	4.8	MEDI		0.002		The Okta Access Gateway includes an optional pass-through authentication source that accepts user identity from a client-supplied HTTP header without cryptographic validation. In architectures where this optional source is enabled without an upstream reverse proxy or firewall configured to sanitize and enforce client headers, an unauthenticated user can supply an arbitrary identity value to initiate a session.
CVE-2026-88038	4.8	MEDI		0.002		cookies is a Node.js library for reading and writing HTTP cookies, used by Koa via ctx.cookies. In versions before 0.9.2 the library validates the cookie name and value against character sets that reject the semicolon separator, but the domain and path options are checked only against a permissive RFC 7230 field-content matcher that allows semicolons, and both are written into the Set-Cookie header unescaped. An a...
CVE-2026-71497	4.7	MEDI		0.002		jsoup is a Java library for working with real-world HTML. From 1.14.3 until 1.23.1, jsoup's HTML parser could incorrectly handle a malformed tag name ending in a control character, causing the tag to acquire the parsing behavior of a different element. When a custom Safelist permits certain raw-text elements, this misparsing can cause content that should remain inert text to be emitted as active markup after seria...
CVE-2026-44401	4.6	MEDI		0.003		Typemill CMS version 2.x contains a persistent cross-site scripting vulnerability in the Markdown parser extension that allows authenticated users with theme-configuration access to inject malicious JavaScript URIs by supplying unsanitized href values in Markdown links. Attackers can craft Markdown links using the javascript: scheme through ParsedownExtension.php or TwigMarkdownExtension.php, storing a persistent ...
CVE-2026-49836	4.6	MEDI		0.002		psd-tools is a Python package for working with Adobe Photoshop PSD files. Prior to version 1.17.1, `SmartObject.save()` writes an embedded smart object to a path taken verbatim from the PSD file. Because that name is attacker-controlled and unsanitised, a tool that extracts embedded objects from an untrusted `.psd` can be made to write attacker-chosen bytes to an attacker-chosen path (absolute or `../`-traversing)...
CVE-2026-78508	4.6	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-0296	4.5	MEDI		0.001	paloaltonetworks:globalprotect	Improper certificate validation vulnerabilities in Palo Alto Networks GlobalProtect™ app enable an unauthenticated attacker with man-in-the-middle (MitM) access to intercept and modify application communications. VPN tunnel traffic is not impacted. The GlobalProtect app on iOS, Android, and Chrome OS is not affected.
CVE-2026-72980	4.4	MEDI		0.003		Uncontrolled search path element in Windows Hello allows an authorized attacker to bypass a security feature locally.
CVE-2026-0305	4.3	MEDI		0.001		An information disclosure vulnerability in the Palo Alto Networks Prisma® Access Agent on Linux enables a local user to access sensitive configuration data and credentials. The Prisma Access Agent on macOS, Windows, iOS, Android and Chrome OS is not affected.
CVE-2026-16941	4.3	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, and 7.4 could allow a remote authenticated attacker to modify certain system messages due to improper authorization.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78516	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows Storage allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-86087	4.3	MEDI		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-9736	4.3	MEDI		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 could allow an unauthorized user to inject data into log messages due to improper neutralization of special elements when written to log files.
CVE-2026-0295	4.1	MEDI		0.001	paloaltonetworks:globalprotect	A race condition in the Palo Alto Networks GlobalProtect™ client on macOS enables a locally authenticated low-privileged attacker to escalate their privileges to root. The GlobalProtect app on Linux, Windows, iOS, Android, and Chrome OS is not affected.
CVE-2026-0309	4.0	MEDI		0.004		A command injection vulnerability in Palo Alto Networks PAN-OS® software enables an authenticated administrator to bypass system restrictions and run arbitrary commands as a root user. To be able to exploit this issue, the user must have access to the PAN-OS CLI and the device must be configured with a Luna Hardware Security Module (HSM). The security risk posed by this issue is significantly minimized when CLI ...
CVE-2026-80159	4.0	MEDI		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Untrusted Search Path vulnerability that could result in privilege escalation. An attacker with high privileges could leverage this vulnerability to gain elevated access. Exploit depends on conditions beyond the attacker's control. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-88059	4.0	MEDI		0.003		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.1, Angular's @angular/common HttpTransferCache can cache an authenticated response when Server-Side Rendering (SSR) and hydration use a hierarchical HttpClient configured with withRequestsMadeViaParent. The child TransferCache evaluates an initially...
CVE-2026-17483	3.3	LOW		0.002	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 IBM i could allow a local attacker to delete historical flight-recorder archives due to improper access control in an SQL procedure.
CVE-2026-28671	3.3	LOW		0.001		In updateInternal of MediaProvider.java, there is a possible expose contents of files due to a race condition. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-45521	3.3	LOW		0.001		In openFile of AppFuseBridge.java, there is a possible information disclosure due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-84389	3.1	LOW		0.001		A url redirection to untrusted site ('open redirect') vulnerability in Fortinet FortiSIEM 7.5.0 through 7.5.1, FortiSIEM 7.4.1 through 7.4.2 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2025-69873	2.9	LOW		0.005		ajv (Another JSON Schema Validator) before 8.18.0 is vulnerable to Regular Expression Denial of Service (ReDoS) when the \$data option is enabled. The pattern keyword accepts runtime data via JSON Pointer syntax (\$data reference), which is passed directly to the JavaScript RegExp() constructor without validation. An attacker can inject a malicious regex pattern (e.g., "(a a)*\$") combined with crafted input to caus...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87525	2.7	LOW		0.001	google:chrome, microsoft:windows	Out of bounds read in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to read memory outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-0303	2.4	LOW		0.001		A code execution vulnerability in Palo Alto Networks Checkov by Prisma® Cloud can allow arbitrary code execution when Checkov scans a directory that contains an attacker-controlled configuration file.
CVE-2026-15418	2.4	LOW		0.002		In the silabser.sys driver for CP210x devices v11.5.0 and earlier, a local unprivileged user with a malicious device can use malformed packets to leak up to 145 bytes of uninitialized kernel pool memory. This vulnerability affects Windows 10 and earlier.
CVE-2026-82865	2.1	LOW		0.001		pdfme schemas before 5.5.10 contains a cross-site scripting vulnerability in the multiVariableText property panel that assigns unsanitized i18n label values to innerHTML. Attackers who control label overrides through options.labels can inject arbitrary JavaScript that executes when users open the Designer and select a multiVariableText field without variable placeholders.
CVE-2026-0302	1.1	LOW		0.008		An OS command injection vulnerability in Palo Alto Networks Checkov by Prisma® Cloud enables a local user to execute arbitrary commands in the processes running Checkov.
CVE-2026-0308	1.1	LOW		0.003		A stored cross-site scripting (XSS) vulnerability in Palo Alto Networks PAN-OS® software enables a malicious authenticated administrator to store or execute a JavaScript payload using the web interface. This issue is applicable to PAN-OS software on PA-Series and VM-Series firewalls and on Panorama (virtual and M-Series). Cloud NGFW and Prisma® Access are not affected by this vulnerability.
CVE-2026-86422	1.0	LOW		0.001	imagemagick:imagemagick	ImageMagick before 7.1.2-30 contains a time-of-check-time-of-use vulnerability in path policy enforcement on Windows that allows attackers to bypass read or write restrictions by exploiting symlink race conditions. Attackers can swap symlinks between policy validation and file access to read or write policy-denied files.
CVE-2026-61634	0.0	NONE		0.003		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.0, the AMQP connection tuning path records the negotiated AMQP frame_max value, but src/main/java/com/rabbitmq/client/impl/SocketFrameHandler.java and NettyFrameHandlerFactory continue to validate broker-controlled frame payload lengths against maxInboundMessageBodySize because the ...

P3/P4 items (1116) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.